

Security+ Certification SY0-701 50 Practice Questions

Tuesday, July 29, 2025 4:52 AM

Exam Information and Domains

Saturday, June 28, 2025 10:49 PM

Information:

- 90-minute time limit
- Maximum of 90 Question
 - Multiple choice (pick one or many)
- Drag and Drop
 - Match objects to diagram
- Performance-based
 - Hands-on troubleshooting scenarios where you'll have to perform a series of steps and commands
- 750 out of 900 is the passing score

Domain:

Domain	% of Exam
1. General Security Concepts	12%
2. Threats, Vulnerabilities, and Mitigation	22%
3. Security Architecture	18%
4. Security Operations	28%
5. Security Program Management and Oversight	20%
Total	100%

Exam Objectives:



11563
Security+ ...

Notes:



Course+Notes

Cram Guide:



Security++
Last+Min...

30-day study plan:



30+Day+study+Plan

IT Security Fundamentals

Saturday, July 12, 2025 9:58 AM

CIA Triad

1. Confidentiality

- a. Refers to the measures taken to ensure that sensitive information is not disclosed to unauthorized individuals, entities, or processes.
- b. Involved preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information
- c. Access controls: passwords, biometric verification, or access cards, ACL.
- d. Encryption: process of encoding information in such a way that only authorized parties can read it.
- e. Secure Communication: using secure protocols like SSL/TLS for transmitting data to prevent interception by unauthorized entities

2. Integrity

- a. Protecting data from unauthorized changes to ensure that it is reliable and correct
- b. Trustworthiness and accuracy of data
- c. Data Accuracy, Data Consistency, Data Trustworthiness
- d. Cryptographic Hash Functions and Digital Signature
- e. Access Controls

3. Availability

- a. Ensures data, systems, and services are accessible to authorized users when needed
- b. Fault Tolerance: Building systems that can continue operating properly even if some of their components fail
- c. Backup systems: Regularly backing up data and systems to enable recovery in case of data loss or corruption

DAD Triade

1. **Disclosure** - Analogous to a breach in confidentiality
2. **Alteration** - Loss of integrity
3. **Denial** - direct attack on availability

Zero Trust - Should not automatically trust anything inside or outside their perimeters and instead must verify anything and everything trying to connect to its systems before granting access

1. Strict identity verification
2. Least Privilege Access
3. Multi-factor Authentication
4. Monitor and Log all traffic

Data Plane:

1. **Implicit Trust Zones** - areas where trust is assumed by default
2. **Subject/System** - entities requesting or being granted access
3. **Policy enforcement point** - responsible for enabling monitoring and eventually terminating connections between a subject and an enterprise resource

Control Plane:

1. **Adaptive identity** - dynamically adjusting user/system identity verification based on context
2. **Policy drive access control** - access granted based on policies rather than static permission
3. **Policy Administrator** - responsible for establishing and/or shutting down communication path between a subject and a resource
4. **Policy Engine** - responsible for ultimate decision to grant access to a resource for a given subject
5. **Threat Scope Reduction** - minimizing the attack surface

Non-repudiation - ensure that a party in communication cannot deny the authenticity of their signature on a document or the sending of a message that they originated.

- Can be implemented using a digital signature
 - o Digital signatures uses cryptographic techniques, a digital signature binds a person to the digital data they send

AAA

1. **Authentication** - process of verifying the identity of a user, device, or other entity in a computer system
2. **Authorization** - process that determines what that user is permitted to do by matching user or system credentials
 - a. Determines what a user is allowed to do by establishing their rights and privileges
 - b. Can be done using: permissions and privileges, access control, authorization models (Mandatory Access Control or Discretionary Access Control)
3. **Accounting/Auditing** - ensures keeping a track of activities. It involves the logging and monitoring of user actions.
 - a. Can be done using: User Activity Tracking - involves collecting data on user activities, such as login times, duration of sessions, accessed resources, network services used, system changes made, and data transferred.

Accountability - ensures individuals or entities are held responsible for their actions within a system

Gap Analysis - an assessment that organizations use to compare their current security posture with a set of standards, best practices, or regulatory requirements to identify areas that need improvement

1. **Identification of current state:** involves mapping out the existing security measures, policies , and controls
2. **Determination of Target State:** typically defined by industry standards, regulatory requirements, or the organization's internal objectives for security
3. **Analysis of the gap:** identifying the differences between the current state and the target state.

Security Controls Categories, and Types

Saturday, July 12, 2025 11:06 AM

Categories:

1. **Technical Security Controls** - or logical security controls, are mechanisms implemented in hardware, software, or firmware that automate the process of preventing, detecting, and responding to security threats
 - a. Access control mechanisms, firewalls, IPS/IDS, encryption, antivirus and antimalware software, virtual private network
2. **Managerial security controls** - administrative controls, these are policies, procedures, and guidelines that govern the behavior of people within an organization and the operation of the IT systems
 - a. Security policies and procedures, risk management, incident response and recovery plans, and business continuity and disaster recovery planning
3. **Operational security controls** - day to day methods and procedures that are implemented by an organization to ensure and maintain the security of its information and assets
 - a. Security awareness training, physical media protection
4. **Physical security controls** - measures taken to protect the actual hardware and facilities that house the systems, networks, and data
 - a. Lighting, signs, fences, security guards, cameras

Types:

1. **Preventive controls** - attempts to stop a security incident from happening
 - a. IPS, Firewalls, encryption, access controls
2. **Detective controls** - attempts to detect events that resulted in a security incident
 - a. IDS, SIEM, video surveillance, motion detection
3. **Corrective controls** - attempts to remediate an incident that has occurred
 - a. UPS, restoring backups, incident response procedures
4. **Deterrent Controls** - attempts to discourage a threat
 - a. Guard dogs, cameras, barbed wires
5. **Directive controls** - provides directions on how to systems
 - a. Policies, procedures
6. **Compensating controls** - provides alternate controls when the primary control may not be sufficient
 - a. Segregation of duties

Defense in Depth/Layered Security - is an information assurance concept where multiple layers of security controls are placed throughout an information technology system

Threats

Saturday, July 12, 2025 11:37 AM

Motivation:

1. **Data Exfiltration** - stealing data from a target, often for selling or leverage
2. **Espionage** - spying on entities to gather sensitive information, common with Nation-States
3. **Service Disruption** - disabling a service, often seen with hacktivists protesting against a specific services or companies.
4. **Blackmail** - threatening to release sensitive data unless a demand, usually monetary, is met
5. **Financial gain** - stealing data or directly siphoning money
6. **Philosophical/political beliefs** - acting based on personal or group beliefs
7. **Ethical** - acting on perceived ethical obligations, sometimes seen with whistleblowers
8. **Revenge** - targeting an entity out of vengeance for a perceived wrong
9. **Disruption or chaos** - motivated purely by desire to create disorder
10. **War** - cyber-operations that are a component of a larger warfare

Threats:

Attributes of Actors:

1. **Internal/External**
2. **Resources/Funding**
3. **Level of Sophistication**
1. **Nation-state** - a country's government which can engage in or sponsor cyber activities
2. **Unskilled Attacker** - individual with limited technical expertise in conducting cyber-attacks, often dubbed as "script kiddies"
3. **Hacktivists** - someone who uses hacking techniques and digital tools to promote a political agenda, social change, or ideological beliefs
4. **Organized Crime** - operations run by criminals who systemically engage in illegal activities for profit
5. **Shadow IT** - refers to IT systems and solutions built and used inside organizations without explicit organization approval

Threat Vectors and Attack Surfaces:

1. **Message-based**
 - a. Email - popular medium for delivering malicious content or links
 - b. SMS - mobile based text messages
 - c. Instant messaging - real-time messaging services
2. **Image-based** - malicious payloads embedded in images
3. **File based** - malicious software can be embedded within files
4. **Voice call** - using phone calls to deceive victims into divulging personal information
5. **Removable device** - USBs and flash drives can be used to introduce malware or exploit software
6. **Vulnerable software:**
 - a. Client based - requires installation on a user's system can be targeted for vulnerabilities
 - b. Agentless - software that runs without installations or agents
7. **Unsupported Systems and Applications** - outdated software that no longer receives security updates
8. **Unsecure Networks:**
 - a. **Wireless**
 - b. **Wired**
 - c. **Bluetooth**
9. **Open Service Ports** - unsecured open ports can allow unauthorized access or attacks
10. **Default Credentials** - devices or systems with unchanged default passwords

11. Supply Chain:

- a. Managed Service Providers (MSPs)**
- b. Vendors**
- c. Suppliers**

Vulnerabilities

Saturday, July 12, 2025 12:26 PM

Vulnerability - refers to a weakness in a system that can be exploited by a threat actor to gain unauthorized access to or perform unauthorized actions on a computer system

1. **Memory injection** - inserting malicious code into a program's memory
 - a. Code injection, buffer overflows, DLL injections
 - b. Buffer overflow - occurs when data that is meant to be stored in a buffer, which is a contiguous block of computer memory, exceeds the buffer's storage capacity
2. **Race Conditions** - occurs when the timing of actions affect a system's state and outcome
3. **Malicious Updates** - attacker attempts to install a fake update to an operating system that actually weakens the security of the operating system
4. **OS-Based Vulnerabilities** - weaknesses in the OS that can be exploited to gain unauthorized access, elevate privileges
5. **SQL injections** - attackers insert malicious SQL code into input fields to run unauthorized SQL entries
6. **XSS** - found in web applications. It enables attackers to inject client-side scripts into web pages viewed by other users
7. **Hardware Vulnerabilities:**
 - a. **Firmware** - weaknesses in low level software that runs on hardware devices
 - b. **End-of-life hardware** - Devices no longer supported by manufacturers
 - c. **Legacy hardware** - older hardware that may not be compatible with current security measures
8. **VM Vulnerabilities:**
 - a. **Virtual Machine Escape** - an attacker runs code on a VM which allows them to break out and interact with the host system
 - b. **Resource Reuse** - sensitive data can remain in system resources
9. **Cloud specific vulnerabilities:**
 - a. **Data Breaches** - data stored on cloud servers may be targeted by hackers
 - b. **Insufficient Identity, credential and access management**
 - c. **Insecure interfaces and APIs**
 - d. **System Vulnerabilities**
 - e. **Account Hijacking**
10. **Supply chain vulnerabilities** - refers to the complex network of suppliers involved in the production and distribution of IT Products and services.
 - a. **Service Providers** - entities deliver various IT services, including cloud computing, data storage, and networking services.
 - b. **Hardware providers** - manufacturers and distributors of physical computing devices and components
 - c. **Software Provider** - entities that develop and distribute software, including OS, applications, and firmware
11. **Cryptographic vulnerabilities** - refers to the weaknesses within the cryptographic algorithms or their implementation that can be exploited to breach security
12. **Misconfigurations** - refer to improper setup or configuration of software, hardware, or network systems
13. **Mobile Device vulnerabilities** - refer to the weaknesses that could potentially be exploited by attackers to gain unauthorized access to a device or its data
 - a. **Jailbreaking** - refers to the process of removing software restrictions imposed by the OS on devices.
 - b. **Sideloaded** - process of installing applications on a mobile device from sources other than the official app store
14. **Zero-day Vulnerabilities** - a security flaw that is discovered by attackers before the vendor of the software is aware of it or before they have released a patch to fix it.

Signs of Attacks

Saturday, July 12, 2025 12:50 PM

Malware - malicious software, any software intentionally designed to cause damage to a computer, server, client, or network

1. **Virus** - type of a malware designed to spread to other computers. It attaches itself to a legitimate software and execute its code when the host software runs
 - a. Infection mechanisms:
 - i. File infector viruses - these attach themselves to executable files
 - ii. Macro viruses - written in the macro language of applications
 - iii. Boot Sector Viruses - they infect in master boot record of a hard drive
2. **Worms** - replicates itself in order to spread to other computers. It does not need to attach itself to an existing program
3. **Trojans** - type of malware that disguises itself as legitimate software or is hidden within legitimate software
4. **Ransomware** - a type of malicious software designed to block access to a computer system or encrypt files until a sum of money is paid
5. **Spyware** - a type of malware that is designed to gather data from a user or organization without their knowledge or consent
6. **Rootkit** - is a computer program designed to provide continued privileged access to a computer while actively hiding its presence from administrators and other system users.
7. **Logic Bomb** - a piece of code intentionally inserted into a software system that will set off malicious function when specified conditions are met
8. **Keyloggers** - a type of software or hardware that has capability to record every keystroke made on that system.
9. **Bloatware** - refers to unwanted software that comes pre-installed on a device or is included in other software installations. It's not inherently malicious like malware but it can slow down systems, take up valuable space, and can include vulnerabilities that might be exploited by malicious actors
10. **DDOS** - a malicious attempt to disrupt the normal traffic of a targeted server, service, or network by overwhelming the target or its surrounding infrastructure with a flood of Internet traffic
 - a. Amplification attacks - this exploit the characteristics of certain protocols to magnify the amount of traffic that is sent to a target. It uses DNS or IP Addressing
 - b. Reflected DDOS - characterized by its use of reflection, meaning the attacker forces third-party servers to direct traffic to the victim. IP Spoofing is one way of doing this.
11. **DNS** - Domain Name System, essentially the Internet's phone book, it translates human-readable domain names into numerical IP addresses that computers use to connect to each other.
 - a. DNS Spoofing or Cache Poisoning - this attacks involves corrupting the DNS cache with false information. An attacker can redirect traffic from a legitimate website to a fraudulent one without the user's knowledge.
 - b. Amplification Attacks - these are a type of DDoS attack where the attacker exploits publicly-accessible DNS servers to flood a target with DNS response traffic.
 - c. DNS Tunneling - involves encoding the data of other programs or protocols in DNS queries and responses
 - d. DNS Hijacking - the attacker diverts queries to a malicious DNS server, leading users to fraudulent websites or intercepting the internet traffic
12. **Onpath Attack** - a type of attack where the attacker positions themselves in the communication path between two parties, this is commonly known as "Man in the Middle" attack.
 - a. Intercepting communication - the attacker intercepts the data traffic flowing between two parties
 - b. Eavesdropping - the attacker passively listen to the communication, gaining access to any transmitted information.
 - c. Session hijacking - the attacker can hijack sessions, by stealing session tokens, allowing

- them to impersonate the victim and gain unauthorized access
 - d. Data Manipulation - these attackers can alter the communication
 - e. SSL Stripping - attacker downgrades a secure HTTPS to an HTTP connection, enabling them to view and modify data exchanged
13. **Credential Replay** - an attacker captures and reuses credentials to gain unauthorized access to a system. This attack exploits scenarios where authentication credentials are transmitted over a network or stored in a way that allows an attacker to intercept and reuse them
- a. Credential capture- this can be done through keyloggers, network sniffers
 - b. Replay the credentials - once credentials are obtained, the attacker attempts to use them to log into the system
 - c. Potential for widespread access
14. **Privilege Escalation** - where an attacker gains elevated access to resources that are normally protected from an application or user
- a. Vertical privilege escalation - when an attacker gains a higher level of privilege than they are supposed to have
 - b. Horizontal - involves an attacker expanding their control across a network at the same level of privileges
15. **Request Forgery** - a type of cyber-attack where the attacker tricks a user's browser or application into performing unwanted action on a trusted site where the user is authenticated.
- a. Cross-site request forgery - the attacker forces a logged-in victim's browser to send a forged request to a web application
 - b. Server-side Request forgery - the attacker manipulates a server to make a request to internal services within the organization or to external third-party systems
16. **Directory Traversal** - an attack which aims to access files and directories that are stored outside the web root folder
17. **Indicators of Malicious Activity:**
- a. Account Lockout
 - b. Concurrent session usage
 - c. Blocked content
 - d. Impossible travel
 - e. Resource consumption
 - f. Resource inaccessibility
 - g. Out-of-cycle Logging
 - h. Published/Documented
 - i. Missing Logs

Cryptography

Saturday, July 12, 2025 3:42 PM

Cryptography - is the practice and study of techniques for securing communication and data in the presence of adversaries. It involves creating written or generated codes that allow information to be kept secret. It both protects information from theft or alteration and can also be used for user authentication.

Terms:

1. **Cryptography** - the art and science of hiding the meaning of communications from unintended recipients
2. **Cryptoanalysis** - the study of methods to defeat codes and ciphers
3. **Cryptology** - cryptography + cryptoanalysis
4. **Cryptovables** - keys are sometimes referred to as cryptovables

Goals:

1. Confidentiality - data is accessible only to those who are authorized to have access
2. Integrity - data has not been altered
3. Authentication - verifying the identity of a user, device, or entity in a communication process
4. Non-repudiation - preventing an entity from denying their involvement in a transaction or activity

Algorithm vs Keys

Cryptographic Algorithm - methods or procedures used to encrypt and decrypt data. This defines how the encryption and decryption processes are to be carried out. The strength and security of an algorithm are determined by its ability to withstand cryptoanalysis and attacks without being fundamentally flawed

Example: Advanced Encryption Standard (AES), Rivest-Shamir-Adleman (RSA), and Secure Hash Algorithm (SHA)

Cryptographic Keys - are strings of bits used by the cryptographic algorithms to transform the data. The security of encrypted data is directly tied to the length and randomness of the key. The longer and more random the key, the more combinations a potential attacker has to try in order to break the encryption.

Ciphers

Block Ciphers - encrypt data in fixed-sized blocks. They are suitable for processing large amounts of data

Example: AES

Stream Ciphers - encrypt data one bit or byte at a time, often used in scenarios where data arrives in a stream. Best for use when the device has limited resources

Example: RC4, but it's now considered insecure

Substitution Cipher - each letter in the plaintext is replaced by another letter

Transposition Cipher - the letters of the plaintext are rearranged according to a certain system. The actual letters are not changed but their order is altered.

Symmetric Encryption - type of cryptographic algorithm that uses the same key for both encryption and decryption. This shared key is used to convert plaintext into ciphertext and vice versa (also called private key and secret key cryptography)

Key Sharing - since the same key is used for both encrypting and decrypting data, it must be shared and kept secret between the communicating parties

Speed and Efficiency - generally faster and more efficient than asymmetric key algorithms, making them suitable for encrypting large amounts of data

Applications - used in various applications like encrypting data for secure storage, data in transit, and files and databases.

Key Management Challenges - the key must be securely shared and stored, which can be challenging in large networks or systems.

Security - depends on the key length and the security of the algorithm itself.

Problems:

1. **Key distribution and management**
2. **Scalability issues** - in a large network, the number of required keys can grow rapidly. $N(N-1)/2$ formula
3. **Key Storage and protection**
4. **Lack of Non-repudiation** - symmetric key cryptography does not provide non-repudiation since the same key is used by all parties.

Example of symmetric algorithm:

1. **Data Encryption Standard (DES)** - is a symmetric-key 64-bit block cipher. It uses a long series of exclusive OR to generate the ciphertext
 - i. 64-bit block, 64-bit key (56 bits effectively)
2. **Triple-DES (3DES)** - applies the DES algorithm three times to each data block. 3 or 2 keys can be used depending on the mode used
3. **International Data Encryption Algorithm (IDEA)** - developed in response to the insufficient key length of DES. Key is divided into 52 16-bit subkeys
 - i. 64-bit block ciphers, variable key size: 64 or 128 bits
4. **Blowfish** - larger keys than IDEA
 - i. 64-bit block cipher, variable key size: 32 - 448 bits
5. **Skipjack** - with support for key escrow
 - i. 64-bit block cipher, 80-bit key

6. **Rivest Cipher 4 (RC4)** - widely used by WEP and older implementations of SSL and TLS
 - i. Stream cipher, variable key size: 40 bits or 2048 bits
7. **Rivest Cipher 5 (RC5)** - not widely adopted
 - i. Variable block cipher: 32, 64, or 128 bits, variable key size: 0 or 2048 bits
8. **Rivest Cipher 6 (RC6)** - next version of RC5
 - i. 128-bit block cipher, variable key size: 128, 192, or 256 bits
9. **Advanced Encryption Standard (AES)** - also known as Rijndael, a specification for the encryption of electronic data established by the US National Institute of Standards and Technology (NIST) in 2001
 - i. 128-bit Block Cipher, variable key size: 128, 192, or 256 bits
 - ii. Number of Encryption rounds is key size dependent

Asymmetric Encryption - also known as public-key cryptography, is a system that used pairs of keys, a public key which may be disseminated widely and a private key, which is only known to the owner.

Key Pairs:

1. **Public** - Shared with anyone
2. **Private** - kept with the owner

Process:

Encryption - sender encrypts data using the recipient's public key, the data can only be decrypted by the corresponding private key

Decryption - recipient uses their private key to decrypt the data. It remains secure since only the recipient possesses the private key

Advantages:

- Solves key distribution problem
- Provides method for digital signatures

Disadvantages:

- Computationally intensive
- Requires careful management of private key

Example of Asymmetric Algorithm:

1. **Rivest-Shamir-Adleman (RSA)** - one of the earliest and most widely used asymmetric cryptographic algorithms. Factoring the product of two large prime numbers
 - i. Key sizes: 1024 to 4096 bits
 - ii. Used in secure data transmission, digital signatures, and SSL and TLS
2. **Elliptic Curve Cryptography (ECC)** - based on algebraic structure of elliptic curves over the finite fields. It offers a higher security with smaller key sizes
 - i. Key sizes - significantly smaller keys than RSA
 - ii. Used in mobile and wireless environments due to its efficiency. Secure messaging, cryptocurrency and SSL and TLS
3. **Diffie-Hellman Key Exchange** - not an encryption algorithm but a method to securely exchange cryptographic keys over a public channels
 - i. Used to set-up a shared secret key for communication in SSL and TLS
4. **ElGamal** - based on Diffie-Hellman, is a public key cryptosystem for both encryption and digital signatures
 - i. Provides basis for other algorithms

Hybrid Cryptography - combines the advantages of both symmetric and asymmetric encryption

Asymmetric encryption - used for secure key exchange

Symmetric encryption - used for encrypting the actual data

Process in encryption:

1. A symmetric key (also known as session key) is generated for each encryption session
2. The symmetric key is then encrypted using the recipients' public key
3. The encrypted symmetric key is sent along with the encrypted data
4. The recipient uses their private key to decrypt the symmetric key and then uses the symmetric key to decrypt the data

Efficiency - combines the efficiency of symmetric encryption with the secure key distribution of asymmetric encryption

Security - even if a symmetric key is compromised, it only affects one session

Scalability - more scalable where numerous users or systems are exchanging data

Usage - TLS and SSL, secure email communication, VPNs, cloud storage services

Hashing - refers to the process of converting an input of any length into a fixed size string of text, using a math function called a hash function. Typically a sequence of numbers and letters known as a hash value or hash digest.

Characteristics:

1. **Deterministic** - same input always produces the same hash value
2. **Fast computation**
3. **Pre-image resistance** - one-way property, computationally infeasible to reconstruct the original input
4. **Small changes lead to large differences**
5. **Collision resistance** - two different inputs not produce the same hash value

Algorithms:

1. **Secure Hash Algorithm** - hash function promoted by NIST
 - i. Digital signatures, certificates
2. **SHA-1** - processes 512-bit blocks to produce a 160-bit message digest
 - i. Deprecated by NIST, multiple collisions

3. **SHA-2** - processes varying block sizes with varying message digest length
 - i. SHA-256 - processes 512-bit block to produce 256-bit message digest
 - 1) SHA-224 - processes 512-bit block to produce a 224-bit message digest
 - ii. SHA-516 - processes 1024-bit blocks to produce a 512-bit message digest
 - 1) SHA-384 - processes 1024-bit blocks to produce 384-bit message digest
4. **SHA-3** - supports the same modes as SHA-2 and made as a drop-in replacement
5. **Message Digest 5 (MD5)** - processes 512-bit blocks to produce 128-bit message digest in 4 rounds, prone to collisions
6. **RIPE Message Digest (RIPEMD)** - series of hash functions provide an alternative to the SHA series of algorithms

Digital Signatures - a technique used to validate the authenticity and integrity of a message, software, or document

Authenticity - digital signatures confirm that the signature was created by the known sender

Integrity - ensure the message was not altered in transit

Non-repudiation - the signer cannot deny the authenticity of their signature on a document since it was created with their private key

Creation of Digital signatures:

1. A digital signature is created using a person's private key.
2. Process involves taking a message, running through a hash function to create a message digest, and then encrypting the digest with the signer's private key.

Verification of Digital signature:

1. To verify, the recipient uses the signer's public key to decrypt the signature
2. The recipient runs the same hash function on the original message to generate a message digest
3. If decrypted signature matches newly generated digest, it confirms that the signature is valid and the message has not been altered.

Digital Signature Standard (DSS) - uses the digital signature algorithm (DSA) developed by the US National Security Agency

- Generates a digital signature for the authentication of electronic documents
- Uses SHA2/SHA3 with RSA or DSA or ECDSA

Public Key Infrastructure - a framework used to create, manage, distribute, use, store, and revoked digital certificates and manage public key encryption. Its purpose is to facilitate the secure electronic transfer of information for a range of network activities such as e-commerce, internet banking, and confidential email.

Functioning of PKI:

1. Encryption and Decryption
2. Digital Signatures
3. Certificate Management

Key Components of PKI:

1. **Digital Certificates** - this provides confirmation that the public key belongs to the specific individual. The document contains the public key that uses a digital signature to bind a public key
2. **Certificate Authority (CA)** - a trusted entity that issues and manages digital certificates. CA verifies the identity of a certificate applicant before issuing a certificate
3. **Registration Authority (RA)** - often acts as the verifier for the CA before a digital certificate is issued to a requestor
4. **Validation Authority (VA)** - checks if the certificate is still valid

Certificate Signing Request (CSR) - used to obtain a digital certificate from a Certificate Authority (CA)

Certificates

Self-signed vs Third-party

Self-signed

- 1) Created by the entity it represents
- 2) Not trusted by others
- 3) Often used in test environments
- 4) No cost associated

Third-party

- 1) Issued and signed by a trusted CA
- 2) High trust because a trusted CA verifies the identity of the certificate holder
- 3) Widely used on the public internet for websites, email servers, and other public facing services
- 4) Typically involves a cost

Root of Trust - refers to the trust anchor in a PKI system. This is usually a root certificate authority that is inherently trusted, and from which the trustworthiness of all other certificates in the network is derived.

Verification - done when user wants to validate your certificate on your device or app

Certificate Pinning - a technique that helps to prevent MITM attacks by hardcoding the SSL/TLS certificate's public key into the app

Revocation - is done when a certificate is compromised, issued by accident, certificate details change, or the security association changes

SSL/TLS Handshake - enables the TLS client and server to establish the secret keys with which they communicate.

1. Agree on the version of the protocol to use.
2. Select cryptographic algorithms.
3. Authenticate each other by exchanging and validating digital certificates.
4. Use asymmetric encryption techniques to generate a shared secret key, which avoids the key distribution problem. TLS then uses the shared key for the symmetric encryption of messages, which is faster than asymmetric encryption.

Steps:

1. The TLS client sends a "client hello" message that lists cryptographic information such as the TLS version and, in the client's order

of preference, the CipherSuites supported by the client. The message also contains a random byte string that is used in subsequent computations. The protocol allows for the “client hello” to include the data compression methods supported by the client.

2. The TLS server responds with a “server hello” message that contains the CipherSuite chosen by the server from the list provided by the client, the session ID, and another random byte string. The server also sends its digital certificate. If the server requires a digital certificate for client authentication, the server sends a “client certificate request” that includes a list of the types of certificates supported and the Distinguished Names of acceptable Certification Authorities (CAs).
3. The TLS client verifies the server's digital certificate. For more information, see How TLS provides identification, authentication, confidentiality, and integrity.
4. The TLS client sends the random byte string that enables both the client and the server to compute the secret key to be used for encrypting subsequent message data. The random byte string itself is encrypted with the server's public key.
5. If the TLS server sent a “client certificate request”, the client sends a random byte string encrypted with the client's private key, together with the client's digital certificate, or a “no digital certificate alert”. This alert is only a warning, but with some implementations the handshake fails if client authentication is mandatory.
6. The TLS server verifies the client's certificate. For more information, see How TLS provides identification, authentication, confidentiality, and integrity.
7. The TLS client sends the server a “finished” message, which is encrypted with the secret key, indicating that the client part of the handshake is complete.
8. The TLS server sends the client a “finished” message, which is encrypted with the secret key, indicating that the server part of the handshake is complete.
9. For the duration of the TLS session, the server and client can now exchange messages that are symmetrically encrypted with the shared secret key.

Steganography - practice of concealing a message, image, or file within another message, image, or file.

Blockchain - a decentralized and distributed ledger technology known for its pivotal role in underpinning cryptocurrencies like Bitcoin. It is a chain of blocks, where each block contains a list of transactions. Each block contains a cryptographic hash of the previous block chaining them together. This ensures that once a block is added to the chain, it cannot be altered without changing all subsequent blocks.

Open public ledger - a decentralized and transparent record-keeping system. This is accessible to anyone and provides a permanent record of all transactions or events that have occurred within a network.

Salting - a technique used to enhance the security of stored passwords or other sensitive data. It involved adding a unique, random string or characters, known as salt, to each password before it is hashed.

Trusted Platform Module - a specialized hardware component designed to secure hardware by integrating cryptographic keys into devices.

Functionality and Purpose:

1. A secure crypto-processor that is designed to carry out cryptographic operations
2. Safeguard the system at hardware level

Key Features:

1. It can generate encryption keys, keeping the private portions of those keys safe with TPM itself

Applications:

1. Disk Encryption
2. Secure boot and system integrity

Secure Enclave - provides a highly secure space within a device where sensitive data can be stored and cryptographic operations can be performed, isolated from the main OS and processor. It ensures that sensitive data is stored in an environment that is segregated from the rest of the device's OS and apps, protecting it from potential vulnerabilities or malware.

Obfuscation - process of disguising confidential or sensitive data to protect it from unauthorized access.

Three Main Types:

1. Data Masking - creates a substitute version of a dataset. The data values are changed but the format remains the same
2. Tokenization - process of substituting sensitive data with non-sensitive equivalents that have no extrinsic or exploitable meaning or value
3. Encryption

Key Escrow - when cryptographic keys are securely stored so that under certain conditions, a third party can access them. This arrangement is often used to facilitate data recovery, ensure compliance with law enforcement requests, or maintain business continuity.

Hardware Security Module - a physical or cloud computing device that provides secure cryptographic processing, key generation and storage, encryption, and decryption services.

Level 1:

1. **Basic Security** - lowest level of security
2. **Physical Security** - No specific physical security mechanisms
3. **Application** - suitable for

Level 2:

1. **Enhanced Security**
2. **Physical Security** - requires physical tamper-evidence
3. **Application** - moderate

Level 3:

- 1. Robust Security**
- 2. Physical Security**
- 3. Application**

Level 4:

- 1. Highest Security**
- 2. Physical Security**
- 3. Application**

Social Engineering

Saturday, July 12, 2025 3:59 PM

Social Engineering - refers to a range of malicious activities accomplished through human interactions. It involves tricking people into breaking normal security procedures and best practices to gain unauthorized access to systems, networks, or physical locations, or for financial gain

Phishing - a type of cyber-attack that attempts to trick individuals into providing sensitive information by masquerading as a trustworthy entity in electronic communication. This is typically carried out via email but can also occur through text messages, social media, or phone calls.

Vishing - a form of phishing where a malicious actor use phone calls to impersonate trusted entities or organization with the primary goal of manipulating individuals into disclosing sensitive information or taking actions that compromise security.

Key characteristics:

1. Urgent or coercive language
2. Spoofed Caller IDs
3. Requests for Sensitive Information

Mitigation:

1. Education and awareness
2. Verification
3. Use of Authentication

Smishing - a form of phishing where a malicious actor use text messages to impersonate trusted entities or organization to manipulate individuals into disclosing sensitive information or taking actions that compromise security

Key Characteristics:

1. Deceptive Messages
2. Requests for Information
3. Spoofed Sender Information

Mitigation

1. Education and Awareness
2. Verification
3. Use of Security Software

Spear Phishing - a targeted form of phishing where the attacker customizes their attack emails, messages, or communications to appeal to specific victims. Unlike general phishing attacks, this is tailored to particular individuals, often using personal or organizational information to appear more legitimate.

Misinformation and Disinformation

Misinformation - refers to the dissemination of false or inaccurate information, often unintentionally or without malicious intent

Key characteristics:

- i. Accidental
- ii. Non-malicious
- iii. Unintentional Consequences

Disinformation - involves the deliberate spreading of false or misleading information with the intent to deceive, manipulate, or harm

Key characteristics:

- i. Deliberate
- ii. Malicious Intent
- iii. Targeted and Coordinated

Mitigation for Misinformation and Disinformation:

- a. Media Literacy and Education
- b. Fact-checking and Verification
- c. Cyber Hygiene and Security Awareness

Impersonation - an attacker assumes the identity of a legitimate user to access a system or network. This can be done through various means such as stealing login credentials, using spoofed email addresses, or mimicking voice or biometric identifiers

Key characteristics:

- 1. Use of stolen credentials
- 2. Deception and Manipulation
- 3. Targets a range of systems
- 4. Difficult to detect

Mitigation:

- 1. Strong Authentication measures
- 2. Password changes and complexity
- 3. User education and awareness training
- 4. Monitoring and Logging
- 5. Incident Response Planning

Business Email Compromise - an attacker gains access to a corporate email account and impersonates the owner to defraud the company, its employees, customers, or partners

Key characteristics:

- 1. Targeted email spoofing
- 2. Sophisticated social engineering
- 3. Financial motive
- 4. High level of customization
- 5. Lack of malware

Mitigation:

- 1. Employee Education and Awareness
- 2. Email Authentication Protocols

Pretexting - involves creating a fabricated story or scenario to deceive a target into divulging sensitive information. The attacker often conducts extensive research to make the story as convincing as possible. It involves the attacker pretending to be someone they are not to gain the victim's trust

Key characteristics:

- 1. Use of Elaborate false scenarios
- 2. Targeting personal or sensitive information
- 3. Manipulating trust
- 4. High level of customization

Mitigation:

- 1. Employee Education and training
- 2. Verification procedures
- 3. Limiting information disclosure
- 4. Incident reporting mechanisms

Watering Hole - a targeted cyberattack strategy where the attacker seeks to compromise a specific group of end users by infecting websites they are known to frequently visit. The goal is to infect a user's computer and gain access to the network at the user's place of employment.

Key characteristics:

- 1. Targeting specific user groups
- 2. Exploiting website vulnerabilities
- 3. Drive-by downloads or malicious redirects

Mitigation:

- 1. Regular website security audits
- 2. Employee awareness and training
- 3. Up-to-date security software

4. Network segmentation and monitoring

Brand Impersonation - a type of cyberattack where an attacker mimics or impersonates the brand identity of a reputable company to deceive victims, usually for the purpose of stealing sensitive information

Key characteristics:

1. Use of counterfeit brand elements
2. Phishing emails and fake websites
3. Exploiting trust in established brands
4. Targets a broad audiences

Mitigation:

1. Brand monitoring
2. Public awareness and education
3. Robust internal security measures
4. Incident response plan

Typosquatting

Key characteristics:

1. Similar or misspelled domain names
2. Exploiting user mistakes
3. Variety of malicious intentions
4. Fake websites or redirects

Mitigation:

1. Awareness and training
2. Use of bookmarks for important sites
3. Advanced web browser and security tools
4. Defensive domain registration

Securing IT Assets

Saturday, July 12, 2025 3:59 PM

Segmentation - is the practice of splitting a network into multiple segments or subnets, each functioning as a smaller, separate network. This division is typically implemented to enhance security, performance, and manageability of the network. Generally done with Virtual LAN (VLAN).

Isolation - refers to the process of completely segregating different parts of a computer network, system, or application to prevent unauthorized access and minimize the risk of contamination from malicious attacks.

Access Control - is the process of granting or denying specific requests to obtain and use information and related information processing services. Users are identified and granted certain rights to access and perform functions with information systems, networks, or databases.

Principles of Least Privilege - refers to the practice of limiting access rights for users, accounts, and computing processes to only those resources absolutely required to perform their functions or tasks. Dictates that individuals or systems should be granted the minimum levels of access or permissions necessary to perform their duties.

Applications:

1. **User Access control** - access to systems and data is restricted based on their job requirements
2. **Administrative Accounts** - system admins may have accounts with extensive privileges for their jobs, but they should use accounts with standard privileges for routine, non-administrative tasks
3. **Software and processes** - these should have only the permissions necessary to function correctly

Access Control List - is a list used by routers and other network devices to authorize or deny traffic to or from particular IP addresses, based on a set of rules. It is also used in file systems for managing permissions and controlling access to directories and files.

File system Permissions - are settings associated with files and directories in a computer's file system that determine who can read, write, and execute a particular file or directory

Categories:

1. **Owner** - the individual who created the file or directory, typically having full permissions to read, write, and execute
2. **Group** - a designated set of users who share certain access levels to the file or directory
3. **Others** - everyone else who has access to the file system but is not the owner or part of the group

Application Allow List - a control mechanism that permits only pre-approved applications to run on a system or network. This approach is opposite to the more common practice of blocking known malicious applications.

Patching - refers to the process of applying updates to software or systems. These can fix vulnerabilities, correct bugs, or provide new features.

Configuration Enhancement - setting up and maintaining hardware and software configurations in an organization according to predefined security standards and policies. It involves actively managing and enforcing these configurations to ensure systems remain secure and compliant.

Decommissioning - refers to the process of formally removing an IT asset from operational use. It involves safely and systematically retiring these assets to ensure no security vulnerabilities are introduced during or after the process.

Monitoring - refers to the process of continuously and actively examining various aspects of a network, system or application to ensure that they are operating securely and efficiently. Uses IDS/IPS, Firewalls, SIEMs, and DLPs

1. Tracking system performance
2. Detecting unusual or suspicious activities
3. Identifying potential security breaches

Hardening Techniques - measures and practices taken to reinforce the security of a system or network. The goal is to reduce vulnerabilities and minimize the attack surface to protect against threats such as unauthorized access, attacks, or data breaches. These techniques often involve configuring system and network settings in a way that maximizes security.

Techniques:

1. **Encryption** - involves converting data into coded format
2. **Disabling Ports/Protocols** - disabling unused or unnecessary network ports and communication protocols
3. **Endpoint protection** - involves installing security software on individual devices like computers and smartphones
4. **Host-based firewall** - a software application that controls network traffic to and from a single host
5. **Host Intrusion Prevention System** - is a comprehensive security solution installed on individual hosts. It monitors and analyzes system behavior and configurations to prevent unauthorized access and other anomalous activities.
6. **Default Password Changes** - practice of altering the preset passwords that come with the hardware and software products
7. **Removal of Unnecessary Software** - involves identifying and uninstalling software applications that are no longer needed or pose security risks.

Security Architecture

Saturday, July 12, 2025 3:59 PM

Cloud

Responsibility Matrix - involves a shared responsibility model where security obligations are divided between the cloud provider and the client

Hybrid Considerations - environments require careful security integration and consistent policy enforcement across both environment

Third-party Vendors - this introduces risks related to vendor security practices and data sovereignty.

Characteristics:

1. **Shared resources** - hardware resources can provide services to devices beyond their physical boundaries
2. **Metered utilization** - pay as you go service, you pay for what you use
3. **Rapid elasticity** - resources can be allocated and reallocated as required to optimize resources usage and cost
4. **High availability** - a hardware failure should have little to no effect on cloud services
5. **File synchronization** - makes files available from anywhere you can access the cloud

Deployment Models:

1. **Public Cloud** - third party hosts the equipment for anyone to make use of their service
2. **Private Cloud** - a third party host the equipment for a single client to have exclusive use of the resources
3. **Community cloud** - is a multi-tenant platform that allows several companies to work on the same platform, given that they have similar needs and concerns
4. **Hybrid cloud** - companies can maintain control of an internally managed private cloud while relying on the public cloud as needed.

Service Models:

1. **Software as a Service** - vendors host the applications, making them available to users via the Internet
2. **Platform as a Service** - offers developers a platform for software development and deployment over the Internet, enabling them to access up-to-date tools
3. **Infrastructure as a Service** - used by companies that don't want to maintain their own on-premises data centers

Infrastructure as Code (IaC) is a concept where hardware is managed like software development. Instead of configuring hardware manually it is managed as a collection of elements in the same way that software and code are managed under DevSecOps).

- Hardware infrastructure is managed like software code with version control, pre-deployment testing, custom-crafted test code, reasonable checks, regression testing, and consistency in a distributed environment.

Serverless Architecture - a cloud computing concept where code is managed by the customer and the platform, or the server is managed by the Cloud Service Provider. There is always a physical server running the code but this execution model allows the software designer to focus on the logic of their code and not have to be concerned about the parameters. This is also known as Function as a Service (FaaS).

Air Gapped - physically isolated or air-gapped networks provide high security by being disconnected from the Internet, but they can be difficult to update and maintain. Nothing can access the system on the network.

Software-Defined Networking - approach to network management that seeks to make networks more flexible, scalable, and programmable.

Separation of Control and Data Planes - SDN decouples the network control logic (control plane) from the underlying routers and switches that forward traffic (data plane). This separation allows for centralized network management and control.

Key components:

1. SDN Controller - brain for the SDN network. It's a software application that manages the flow of control to the network devices
2. Southbound interface - protocols like OpenFlow that relay instructions from the SDN controller to the switches and routers
3. Northbound interface - facilitate communication between the SDN controller and the applications and business logic above. They allow for the development applications that can dynamically control network behaviors

Advantages:

1. Flexibility and Agility - easier to configure and reprogram the network on the fly to meet changing needs
2. Centralized management - network admins can manage the entire network as a single entity from a central location
3. Improved network efficiency and performance - automated and dynamic traffic routing can lead to more efficient network utilization.
4. Cost-effectiveness - reduces the need for expensive, proprietary hardware and facilitates the use of commodity hardware

On-Premises - is fully controlled and managed internally, offering complete control over security but also requiring significant resource for security management

Centralized vs Decentralized:

Centralized systems - can enforce consistent security policies but create single points of failure.

Decentralized systems - can enhance resilience and reduce single points of failure but can complicate security monitoring and consistency.

Virtualization - is the creation of a virtual version of something. Used to host one or more operating systems within the memory of a single host computer. Allows virtually any OS to operate on any hardware. Easier and faster to make backups of the entire virtual system. (Example: VMWare, Hyper-V, Virtual box)

Offers:

1. Individual instances of servers or services
2. Real-time scalability
3. Quick recovery from damaged, crashed or corrupt virtual systems
4. Help desk support

Hypervisors - a type of software, firmware or hardware that creates and runs virtual machines. It allows multiple OS to share a single hardware host.

Type 1 - also known as bare-metal hypervisors, these run directly on the host's hardware to control the hardware and manage guest OS

Type 2 - these run on a conventional OS just like other computer program. They are often used for testing and development environments where performance is not a critical issue.

Containerization - is the evolution of virtualization for internally hosted systems and cloud providers and services.

- Eliminates duplicating OS elements like virtualization
- Containers only include the required resources to support the functionality of the application in the container
- Some deployments eliminate the hypervisor altogether and replace it with a collection of common binaries
- Provides 10 to 100 times more application density per physical server than virtualization solutions
- Container engines can run multiple, isolated, instances on the same OS kernel

High Availability - design approach in systems engineering aimed at ensuring an agreed level of operational performance, typically uptime, for a higher than normal period

- **Minimized Downtime** - primary goal of high availability. This ensures that the system or service is consistently available to users
- **Redundancy** - a core component. It involves having backup components that can take over in case the primary components fail
- **Failover Mechanisms** - HA systems often have automated failover processes that allow the system to switch seamlessly to backup systems without service interruption in case of a failure
- **Reliability and Stability** - HA systems need to be both reliable and stable

Internet of Things (IoT) - is the network of physical objects that traditional do not require access to the internet. They provide home and office automation, remote control, monitoring and other conveniences.

Industrial Control System (ICS) - is a general term that encompasses several types of systems used in industrial production.

- **Supervisory control and data acquisition (SCADA)** - systems, distributed control systems, and other smaller control system configurations such as programmable logic controllers often found in the industrial sectors and critical infrastructures

Security Architecture Considerations - when designing and evaluating security architecture models, various considerations come into play.

1. **Availability** - crucial for ensuring that systems and services are always accessible to users
2. **Resilience** - systems are designed to handle and quickly recover from failures, attacks, or errors
3. **Cost** - balancing security needs with budget limitations is a key challenge
4. **Responsiveness** - ability to detect and respond to security threats rapidly is crucial
5. **Scalability** - ensures that the security architecture can adapt to growing needs of the organization
6. **Ease of Deployment** - simplicity and straightforwardness of deploying security solutions are critical
7. **Risk transference** - it's important to understand the terms of such transfers, including what risks are covered, to what extent, and the reliability of the third party in managing these risks
8. **Ease of Recovery** - the ability to recover from security incidents quickly minimizes operational disruption and data loss
9. **Patch Availability** - regularly updating systems with available patches is critical for protecting against known vulnerabilities
10. **Inability to Patch** - in scenarios where patching is not feasible, alternative security measures are necessary
11. **Power** - efficient use of power contributes to the sustainability and cost-effectiveness of the security architecture
12. **Compute** - insufficient compute resources can lead to bottlenecks and decreased security effectiveness

Real-Time Operating System - a specialized OS designed for managing the hardware resources of a computer or embedded system in a way that ensures that specific tasks are executed within strict time constraints

1. **Determinism** - repeating an input will result in the same output
2. **High performance** - RTOS are fast and responsive, often executing actions within a small fraction of the time needed by a general OS
3. **Safety and security** - frequently used in critical systems when failures can have catastrophic consequences, such as robotics or flight controllers.
4. **Small footprint** - versus their hefty general OS counterparts, RTOSes weigh in at just a fraction of the size

Embedded System - are specialized computing systems that perform dedicated functions or are designed for specific functionalities within a larger system.

1. **Dedicated Functionality** - these systems are designed for specific tasks
2. **Integration with Hardware** - often closely integrated with their physical environment and

hardware

Security Principles

Saturday, July 12, 2025 3:59 PM

Infrastructure Considerations - refers to the various aspects of an organization's IT infrastructure that need to be secured and managed to protect against cyber threats

Device Placement - strategic positioning of hardware components within an IT infrastructure. This includes considering the physical and network locations of devices such as servers, routers, switches, and others. Environmental factors, redundancy, and scalability are also important considerations.

Security Zones - segments within a network that have distinct level of security controls and are separated by logical or physical means. Commonly security zones include external zone, demilitarized zone (DMZ), and internal zone (private network).

Attack Surface - refers to the total number of point where an unauthorized user can try to enter or extract data. It includes all the exposed areas that are vulnerable to cyberattacks.

Failure Modes - different manners or conditions under which a system, network, or component can fail to perform its intended function. It encompasses scenarios that could lead to security breaches or data loss.

Fail-open - system defaults to an open-state during a failure.

- i. This means if the system fails, it allows access or traffic to pass through
- ii. In physical security, it may fail-open to allow people to get in and out

Fail-closed - the system defaults to a closed or locked state when a failure occurs.

- i. This means it denies access or stops traffic if a failure is detected

Device Attributes - refers to the inherent properties and operational behaviors of network security devices. This determines how the device interacts with the network traffic and its role in the network's security architecture.

Active - interact with and actively modify or influence network traffic. They can make real-time decisions, such as blocking, redirecting, or modifying traffic.

Passive - monitor and analyze network traffic without altering it. They typically gather and report data or alert on suspicious activities.

Inline - the device is placed directly in the path of network traffic. Essential for proactive security measures, where immediate action is required against threats.

Tap or monitor mode - the device is connected in a way that allows it to observe traffic passively without being in the direct traffic path. Ideal for ongoing monitoring and threat detection without impacting network performance.

Network Appliances - specialized devices designed to perform specific functions within a network, often related to security and data management. They are typically optimized for tasks such as routing, switching, security, load balancing, and storage.

Sensors - devices or software components that collect and analyze data from a network or system to identify potential security threats or anomalies. In exam, questions about sensors might focus on their roles in detecting and preventing security breaches, types of sensors, and their specific uses.

Jump Server - is a secure computer that acts as a controlled entry point into a remote network or server group. It's a gateway between two networks, often used by system administrators and IT professionals to manage and access devices in a separate security zone.

Proxy Servers - acts as an intermediary between a user's computer and the internet. It requests resources such as web pages, files, or services on behalf of the user.

Anonymity and Security - it can mask the user's IP address, enhancing privacy and security

Content Filtering - often used to control internet usage in an organization by blocking access to specific websites

Caching - can cache frequently accessed content to improve load times and reduce bandwidth usage.

Types:

1. **Forward Proxy** - sits in front of a client and ensures that no direct connection is made between the client and the internet. It can cache content, filter requests, and hide the client's IP address
2. **Reverse Proxy** - sits in front of web servers and directs client requests to the appropriate backend server. It's commonly used for load balancing, caching, or SSL encryption
3. **Open Proxy** - Conceals your IP address from the websites you visit

Intrusion Detection System (IDS) - a technology for real-time monitoring and analysis of network activity and data for potential intrusions and attacks in progress.

1. Monitor and analyze user and system activities
2. Auditing of system and configuration vulnerabilities
3. Assess the integrity of critical system and data files
4. Recognition of a pattern reflecting known attacks
5. Statistical analysis for abnormal activities

Behavior/Anomaly Based Detection

1. References a baseline or learned pattern on normal system activity to identify active intrusion attempts
2. Build statistical profiles of user activity over time
3. Deviations from this baseline or pattern cause an alarm to be triggered.

Advantages:

- i. Dynamically adapt to new, unique, or original attacks
- ii. Less dependent on identifying specific OS vulnerabilities

Disadvantages:

- i. Higher false alarm rates than knowledge based IDS
- ii. Usage patterns may change often and may not be static enough to implement an effective behavior-based IDS

IDS Response:

- i. **Passive Response** - logs the event and sends a notification. Notifications can be sent to admins via email, text, or pager messages, or pop-up messages. Alerts can generate reports detailing the activity leading up to the event
- ii. **Active Response** - changes the environment to block the activity in addition to logging and sending a notification. Responses include modifying ACLs to block traffic based on ports, protocols, and source addresses. It can disable all communications over specific cable segments.

Host-Based IDS - a system that monitors a host machine on which it is installed to detect an intrusion and/or misuse. Responds by logging the activity and notifying the designated authority.

Advantages:

- i. Can detect anomalies on the host system that NIDS cannot
- ii. Many HIDS include antimalware capabilities

Disadvantages:

- i. More costly than NIDS
- ii. Require administrative attention on each system
- iii. Can't detect network attacks on other systems
- iv. Often consumes a significant amount of system resources, degrading the system performance
- v. Easier for intruder to discover and disable HIDS
- vi. Logs that are maintained in the system are susceptible to modification during a successful attack

Network-Based IDS - used to monitor and analyze network traffic to protect a system from network-based threats. It can't monitor the content of the encrypted traffic.

Advantages:

- i. Harder for attackers to discover and disable
- ii. Has very little negative effect on the overall network performance

Intrusion Prevention System (IPS) - a network security/threat prevention technology. Examines network traffic flows to detect and prevent vulnerability exploits. It can choose what traffic to forward and what traffic to block after analyzing it

Load Balancer - a device or software that evenly distributes network or application traffic across multiple servers to prevent any single server from becoming overburdened which improves overall performance and reliability

Hardware Load Balancers - physical devices specifically designed for load balancing.

Software Load Balancers - applications that can run on hardware or cloud environments. They offer more flexibility and are often more cost effective.

Setups:

1. Active/Passive Setup

- i. Primary role - one balancer is active and handles all the traffic while the other remains passive.
- ii. Failover Mechanism - if the active load balancer fails, the passive load balancer takes over. This switch is typically automated to ensure minimal disruption
- iii. Usage - ideal for scenarios where uninterrupted service is critical but where simultaneous operation of two load balancers is not necessary
- iv. Advantage - provides reliable backup in case the primary load balancer fails, ensuring continuity of service

2. Active/Active Setup

- i. Primary role - both load balancers are active and share traffic load simultaneously
- ii. Load Distribution - traffic is distributed between the two load balancers based on predefined rules or algorithms
- iii. Usage - suited for high-traffic environments where load distribution is essential for optimal performance
- iv. Advantage - enhances capacity and reliability of the service

Port Security - measures and techniques used to secure network ports on computers and network devices, guarding against unauthorized access and ensuring secure communication channels.

802.1x - an IEEE standard for port-based Network Access Control. It is used to authenticate devices that are attempting to connect to a LAN or WLAN.

Extensible Authentication Protocol - is a framework frequently used in network access control for various authentication methods. It is designed to support multiple authentication mechanisms, including passwords, tokens, certificates, and public key encryption.

Firewalls - a network security system that monitors and controls incoming and outgoing network traffic based on predetermined security rules. It establishes a barrier between a trusted, secure internal network and another outside network that is assumed not to be secure or trusted.

Types:

1. **Packet Filtering Firewalls** - most basic type, which inspects packets and permits or denies them based on source and destination IP addresses, ports, and protocols.
2. **Stateful Inspection Firewalls** - more advanced than packet filtering, these track the state of active connections and make decisions based on the context of the traffic
3. **Web Application Firewall (WAF)** - specifically designed to protect web applications by filtering and monitoring HTTP traffic between a web application and the Internet
4. **Unified Threat Management** - provide a comprehensive solution that combines multiple security features and services in a single device. It includes anti-virus, anti-spyware, firewall, IDS/IPS, and content filtering
5. **Next-Generation Firewalls (NGFW)** - more advanced form of the traditional firewall, integrating additional functionalities such as deep packet inspection, IPS, and application awareness. It goes beyond port/protocol inspection and blocking, to inspect data within the packets themselves.

Layer 4 vs Layer 7

- Layer 4 (transport layer) and Layer 7 (Application Layer) in the OSI model directly impacts the firewall's capabilities and the types of threats it can mitigate
- Layer 4 firewalls focus on data transport and operate at the transport layer. They control traffic based on TCP/UDP ports and session information
- Layer 7 firewalls inspect the content of the traffic. They can make informed decisions based on actual data and application-specific behaviors

Virtual Private Network (VPN) - a technology that creates an encrypted connection over a less secure network. It is created by establishing a virtual point-to-point connection through the use of dedicated connections, data encapsulation, virtual tunneling protocols, or traffic encryption.

Tunneling - encapsulation of a protocol deliverable message within a second protocol.

Transport Layer Security - operates at transport layer. Uses TLS/SSL for encryption of data. No need to open additional ports, uses port 443. Mostly used on user access VPN

L2TP - is a standard protocol for tunneling L2 traffic over an IP network. Hybrid of Layer 2 forwarding (L2F) and PPTP

IP Security (IPSec) Protocol - a standalone VPN protocol. A security mechanism for L2TP. Provides secure authentication and encryption.

Software-Defined Wide Area Network - approach to simplify branch office networking and assure optimal application performance. It provides a centralized control function to securely and intelligently direct traffic across the WAN. It ensures more efficient data routing, reduced latency, and improved overall network performance.

Secure Access Service Edge (SASE) - a cloud native networking architecture that combines network security functions with WAN capabilities to support the dynamic secure access needs of organizations. It merges SD-WAN capabilities with comprehensive security services.

Selecting Effective Controls - process of identifying and implementing right security measures to mitigate risks and enhance an organization's overall security.

Critical Considerations:

1. **Risk Assessment Foundation**
2. **Layered Defense Approach**
3. **Evaluating Cost vs Benefit**
4. **Adhering to Regulations**
5. **Technical Suitability**

Key Factors:

1. **Addressing Specific Risks**
2. **Scalability and Adaptability**
3. **Ongoing Evaluation**

Data Protection

Saturday, July 12, 2025 4:00 PM

Regulated Data - includes data that is subject to regulatory requirements, such as personal data protected under laws like GDPR, HIPAA, or PCI-DSS. Compliance with legal and regulatory standards is crucial.

Intellectual Property - refers to creations of mind like invention, literary works, artistic works, design, symbols, and names used in commerce. IP theft can result in significant economic loss and competitive disadvantage.

Trademarks - protects words, names, symbols, sounds, shapes, colors, musical tones, or combinations used to identify products to distinguish from others

Patents - protect the rights of inventors and their inventions

Trade Secrets - any form of information, device, method, process, or formula that, if disclosed, will cause significant damage to an organization

Legal Information - encompasses information pertaining to legal matters, including case files, legal advice, and other sensitive legal documents

Financial Information - data includes details about transactions, financial records, credit information, and other monetary data

Readable Data

- **Human-readable data**
- **Non-Human readable data**

Data Classification - help in determining the level of security controls and handling protocols that should be applied to various types of data

Geolocation - relates to the physical or geographical location of data

Data Sovereignty - legal concept that data is subject to the laws and governance structures of the country in which it is collected, stored, and process.

Methods to Secure Data

1. Geographic restrictions
2. Encryption
3. Hashing
4. Masking
5. Tokenization
6. Obfuscation
7. Segmentation
8. Permission restrictions

Common Security Techniques

Saturday, July 12, 2025 4:00 PM

Secure Baselines - refers to a set of security standards and configurations that an organization establishes to protect its systems and data

Steps:

1. Establish
 - i. Assessment and analysis
 - ii. Defining standards and configuration
 - iii. Documentation
2. Deploy
 - i. Implementation
 - ii. Automation and Tools
 - iii. Verification and Compliance Checking
3. Maintain
 - i. Monitoring and Auditing
 - ii. Updating and Patching
 - iii. Training and Awareness

Hardening Targets:

1. **Mobile Devices** - involves implementing strong authentication, encrypting data, installing security software, controlling app permissions, and regularly updating the OS and apps
2. **Workstations** - hardened by installing antivirus and anti-malware software, enabling firewalls, regularly applying patches and updates, and implementing user access controls
3. **Switches** - involves disabling unnecessary services, securing management interfaces, implementing VLANs for network segmentation, and using ACLs to control network traffic
4. **Routers** - hardening includes changing default passwords, disabling unused services and interfaces, updating firmware, using strong encryption for Wi-Fi, and setting up firewalls and intrusion prevention systems
5. **Cloud Infrastructure** - using strong identity and access management, encrypting data at rest and in transit, securing APIs, implementing network security control, and following best practices provided by the cloud service provider
6. **Servers** - installing necessary security updates, minimizing the number of running services, implementing strong authentication mechanisms, using firewalls and intrusion detection systems, and physically securing server environments
7. **Industrial Control Systems** - segmenting networks, restricting physical and network access, disabling unnecessary services, applying patches carefully, continuously monitoring for abnormal activities
8. **Embedded systems** - using secure boot processes, implementing least privilege access controls, securing communication channels, and conducting regular security audits to identify vulnerabilities
9. **Real-Time Operating Systems** - minimizing the attack surface by reducing the number of services, implementing strict access controls, and regularly updating the software to fix vulnerabilities
10. **Internet-of-Things** - changing default credentials, securing network connections, regularly updating firmware, disabling unnecessary services, and implementing security at the application layer

Mobile Device Managements - software applications that allow IT admin to control, secure, and enforce policies on mobile devices. It is critical for ensuring that mobile devices comply with organizational security policies and standards, MDM tools monitor health and security of mobile devices, providing insights into compliance status, potential security risks, and usage patterns.

Mobile Connection Methods:

1. **Cellular**
2. **WiFi**
3. **Bluetooth**

Wireless Security:

1. **Wi-Fi Protected Access 3 (WPA3)** - protocol designed for securing wifi networks. The latest security certification developed by the Wi-Fi alliance. Stronger encryption using the Simultaneous Authentication of Equals (SAE). Protection against offline dictionary attacks.
2. **AAA** - a framework for intelligently controlling access to computer resources, enforcing policies, and auditing usage
3. **RADIUS** - a networking protocol that provides centralized AAA for users accessing a network
4. **Cryptographic protocols** - series of processes that encrypt data to secure communications
5. **Authentication protocols** - used to verify the identity of a user or device trying to access a network or service

Application Security - a critical aspect of cybersecurity, focusing on ensuring that software applications are protected from threats and vulnerabilities

Methods:

1. **Input validation** - involves verifying the data provided by a user or another application before processing it. This is crucial to prevent common vulnerabilities such as SQL injection, XSS, and command injection
2. **Secure Cookies** - cookies that have security attributes set to protect user data and session information
3. **Static Code Analysis** - process of examining the source code of an application without executing it. The aim is to find vulnerabilities, code flaws, and ensure compliance with the coding guidelines
4. **Code Signing** - a process that involves using a digital signature to sign executables and scripts. This signature confirms the software author and guarantees that the code has not been altered or corrupted since it was signed
5. **Sandboxing** - a powerful technique used to isolate applications, processes, or programs in a separate environment to prevent them from affecting the underlying system

Security Monitoring:

Key Components:

1. **Network Monitoring** - involves tracking and analyzing network traffic to detect anomalies, unauthorized access, or signs of malicious activity.
2. **System and Application Monitoring** - focuses on the performance and security of specific systems and applications
3. **Log Management and Analysis** - collecting and analyzing logs from various sources to detect unusual or suspicious activity

Purpose and Benefits:

1. **Threat Detection** - early identification of potential security threats
2. **Performance Management** - ensuring that IT infrastructure operates efficiently and identifying areas for improvement
3. **Compliance and Auditing** - helps in maintaining compliance with various regulatory standards by providing evidence of security monitoring and incident response
4. **Insight and Analysis** - provides valuable insights into security posture of the organization and helps in understanding attack patterns and trends

Types of Monitoring:

1. **Real-time Monitoring:**
 - i. **Immediate analysis** - and alerts for ongoing activities, crucial for rapid response to potential threats
2. **Periodic Monitoring** - regularly scheduled checks and analyses suitable for less critical systems or for complementing real-time monitoring.

Hardware, Software and data asset management

Saturday, July 12, 2025 4:00 PM

Acquisition Procurement - process for hardware, software, and data assets carries significant security implications for organizations

Assessment: importance of accuracy

Vendor Evaluation: Vendor risks, Supply chain attacks

Assignment/Accounting

Ownership - refers to the designation of responsibility for an asset to an individual or a department within an organization. It ensures that there is a specific party responsible for the security, maintenance, and compliance of each asset

Classification - involves categorizing assets based on their sensitivity, value, and the impact on the organization if compromised. This is to apply appropriate level of security controls based on the classification

Types:

1. Public
2. Internal-only
3. Confidential
4. Highly-confidential

Monitoring and Tracking:

Inventory Management:

Key Components:

1. Asset Identification - cataloging all assets, including their type, model, specifications, and version
2. Ownership and responsibility - recording who is responsible for each asset
3. Lifecycle management - keeping track of the lifecycle of each asset, from acquisition through disposal

Security Implications - a well-maintained inventory allows for the identification of unauthorized or rogue devices and software

Challenges - keeping the inventory up-to-date in dynamic environments where new assets are frequently added and old ones are retired or repurposed

Enumeration:

Key Aspects:

1. Network Scanning - using tools to scan the network for connected devices and open ports
2. Service identification - determining what services are running on each identified device
3. Vulnerability mapping - relating the gathered information to known vulnerabilities and potential threats

Security Implications - helps in preemptively identifying and addressing security weaknesses

Challenges - ensuring that enumeration activities do not disrupt normal business operations

Disposal and Decommission - process in cybersecurity is not just about removing assets from the operational environment, it's about ensuring that the end-of-life handling of these assets does not introduce new security risks

Sanitization - involves removing sensitive data from storage devices to ensure that it cannot be recovered by unauthorized individuals

Methods:

1. Physical destruction
2. Degaussing
3. Overwriting

Security implications - proper sanitization is crucial to prevent data breaches and

comply with data protection laws and regulations

Challenges - ensuring that the chosen sanitization method is appropriate for the type of storage medium and sensitivity of the data

Destruction - involves physical dismantling or destruction of hardware to ensure it cannot be used again. It is often used when storage devices cannot be reliably sanitized or when the device itself is a security risk

Security implications - a definitive way to ensure data cannot be recovered and that the device cannot be repurposed for malicious activities

Challenges - must be carried out in a way that is environmentally responsible and in compliance with waste disposal regulations

Certification - refers to the documentation or certification process that confirms the proper sanitization and destruction of assets. It serves as proof that the organization has responsibly and securely disposed of its IT assets

Security implications - helps in demonstrating compliance with legal and regulatory requirements related to data privacy and environmental standards

Challenges - ensuring that the certification process is thorough and reflects all necessary compliance and regulatory standards

Data Retention - involves retaining certain data for a specified period as required by law or organizational policies, even during disposal process

Security implications - retained data must be protected according to its classification

Challenges - managing the retention of large volumes of data and ensuring that only the necessary data is retained

Vulnerability Management

Saturday, July 12, 2025 4:01 PM

Vulnerability Scan - automated tools scan systems, networks, and applications to identify known vulnerabilities, such as unpatched software, misconfigurations, and security weaknesses.

Application Security Testing:

1. **Static Analysis** - involves examining application code to detect security flaws without executing the program, aka Static Application Security Testing (SAST). Useful for finding issues like code injection, buffer overflows, and other vulnerabilities that can be identified by reviewing code
2. **Dynamic Analysis** - testing applications in runtime to identify security issues that only appear during execution, aka Dynamic Application Security Testing (DAST). Helps in detecting issues like runtime errors and memory leaks that static analysis might miss
3. **Package Monitoring** - monitoring the software libraries and packages used in applications for known vulnerabilities. It involves keeping track of updates and patches for third-party components integrated into applications

Threat Feeds:

1. **Open-Source Intelligence (OSINT)** - gathering data from publicly available sources to identify emerging threats and vulnerabilities
2. **Proprietary/Third Party** - subscribing to specialized services that provide information on the latest threats and vulnerabilities. Offers more tailored and often real-time information
3. **Information-sharing organization** - participating in groups like ISACs (Information Sharing and Analysis Centers) for industry-specific threat intelligence
4. **Dark Web** - monitoring dark web forums and marketplaces to gather intelligence on new vulnerabilities, exploits and threat actor tactics

Penetration Testing - the practice of testing a computer system, network, or web application to find vulnerabilities that an attacker could exploit

Goals:

1. Determine the feasibility of a particular set of attack vectors
2. Identify high-risk vulnerabilities from a combination of lower-risk vulnerabilities exploited in a particular sequence
3. Identify vulnerabilities that may be difficult or impossible to detect with automated network or application vulnerability scanning software
4. Assess the magnitude of potential business and operational impacts of successful attacks
5. Test the ability of network defenders to detect and respond to attacks
6. Provide evidence to support increased investments in security personnel and technology

Types:

1. **Black Box test** - Zero knowledge, closed test, usually external location, outsider's perspective
2. **Grey Box test** - Partial knowledge, limited info, IP address, domain name, applications, could also mean internal test, insider's perspective
3. **White Box test** - full info, documentation, crystal or open test, system admin's perspective

Kinds of Testers:

1. **White hat** - ethical hacker, tests with permission of the owner
2. **Black hat** - unethical hacker, tests without owner authorization, usually with malicious intents
3. **Grey hat** - undecided, work as both black and white hat
4. **Script Kiddie** - person with little or no skills, uses someone else's script, performs attacks on comp systems, typically meant as an insult

Methods:

1. **Reconnaissance/Discovery** - foot-printing, scanning, passive vs active
2. **Enumeration**
3. **Vulnerability Research**
4. **Execution/Penetration**
5. **Clean after yourself**
6. **Document Findings**

Bug Bounty Program - encourages ethical hackers to report vulnerabilities in exchange for rewards. It helps in identifying and addressing vulnerabilities before they are exploited in the wild

False positive vs False negative:

False Positive - occurs when a system incorrectly identifies a normal or benign activity as a threat. It requires verification to avoid wasting resources on non-existent issues

False negative - happens when a system fails to detect an actual vulnerability or threat. More dangerous as it leaves the systems unknowingly exposed to potential exploits

Common Vulnerability Enumeration (CVE) - a list or database of publicly known cybersecurity vulnerabilities and exposures (<https://www.first.org/cvss>)

Prioritization - involves ranking vulnerabilities based on their severity, potential impact, and the likelihood of exploitation. It helps in focusing resources and efforts on the most critical vulnerabilities that pose the greatest risk

Exposure Factor - represents the potential loss or damage to an asset if a vulnerability is exploited. It helps in evaluating the potential impact of a vulnerability on the organization's assets

Environmental Variables - crucial for contextualizing the risk posed by a vulnerability

Risk Tolerance - level of risk an organization is willing to accept, influenced by its risk management strategy, business objectives, and regulatory environment. Determines how aggressively an organization should respond to different levels of vulnerabilities.

Vulnerability Response and Remediation - critical components of cybersecurity, ensuring that vulnerabilities in software systems are addressed promptly to minimize the risk of exploitation

1. **Patching** - involves applying updates to software systems to fix security vulnerabilities that have been identified
2. **Insurance** - type of policy that provides coverage against losses from cyber incidents, including data breaches and cyberattacks
3. **Segmentation** - dividing a network into smaller parts to control access and reduce the potential impact of a breach
4. **Compensating Controls** - security measures that are put in place to offset the risk when standard controls cannot be applied
5. **Exceptions and Exemptions** - situations where standard security policies or controls are not applied, often due to specific requirements or limitations
6. **Validation of Remediation** - ensures that the measures taken to fix vulnerabilities are effective and that systems are secure
 1. **Rescanning** - using automated tools to scan the systems or applications that were subject to remediation efforts
 2. **Auditing** - refers to a thorough review and examination of security measures and processes related to the remediation efforts
 3. **Verification** - process of confirming that the remediation efforts have not only closed the identified vulnerabilities but also they haven't introduced new vulnerabilities or negatively impacted the system's performance or functionality
7. **Reporting** - involves the documentation and communication of findings related to vulnerabilities in an organization's system and networks

Internal Assessments/Audits - conducted within an organization by its own employees or a designated internal audit team

Compliance - ensures that the organization complies with relevant cybersecurity regulations

and standards

Audit Committee - ensures that audits are conducted objectively, thoroughly, and in alignment with the organization's strategic goals.

Self-assessments - involve the org's IT and security teams regularly evaluating their own cybersecurity measures and controls.

External Assessments - conducted by entities outside of the organization being evaluated

Alerting and Monitoring IT

Saturday, July 12, 2025 4:01 PM

Monitoring Resources - involves continuously overseeing various components of IT infrastructure, including systems, applications, and the broader infrastructure

1. **Systems monitoring** - focuses on health and performance of individual computing systems, such as servers, workstations, and other endpoint devices
 - a. Key aspects - unusual or unauthorized changes in system config, resource utilization, system uptime, performance metrics
 - b. Security Implications - orgs can detect potential security incidents, such as a system compromise or unauthorized access, and respond quickly
2. **Application monitoring** - concerned with the performance and security of software applications. It involves tracking application performance, user activity, error logs, transaction times.
3. **Infrastructure monitoring** - refers to overseeing the entire IT infra of an org. Its goal is to ensure the integrity, availability, and performance of the infrastructure. It involves monitoring of network traffic, health and status of routers, switches, firewalls, and other networking devices, and performance and security of data storage systems

Monitoring Activities:

1. **Log Aggregation** - involves collecting and consolidating logs from various sources within the IT environment. It simplifies analysis, aids in detecting patterns or anomalies, and comprehensive security monitoring.
2. **Alerting** - process of configuring security systems to notify admins or security teams of potential security incidents
3. **Scanning** - encompasses various types of security scans, such as vulnerability scans, network scans, and application scans
4. **Reporting** - involves generation of detailed reports about the security status of the IT environment. It can include details of identified vulnerabilities incidents and the outcome of the security scans
5. **Archiving** - securely storing historical security data, such as logs and incident reports, for future reference.
6. **Alert Response and Remediation/Validation:**
 - a. **Quarantine** - isolating infected systems or components to prevent the spread of a threat or further damage.
 - b. **Alert Tuning** - refining alerting mechanisms to reduce false positives and ensure that alerts are relevant and actionable

Alerting and Monitoring Tools: SIEM and DLPs - variety of tools to ensure the integrity and security information systems

1. **Security Content Automation Protocol (SCAP)** - a suite of standards for automating the process of configuring and monitoring network devices for compliance with security policies
2. **Benchmarks** - refer to the standardized set of best practices and configurations that are known to ensure a higher level of security
3. **Agents/Agentless** - software agents are installed on servers or devices to monitor, collect, and send data back to a central server for analysis. Agentless systems monitor devices without installing dedicated software on them, often using existing protocols and services. Agent-based is more detailed but can be more resource extensive while agentless solutions are easier to deploy but offers less comprehensive data
4. **Security Information and Event Management (SIEM)** - provides real-time analysis of security alerts generated by applications and network hardware. It is used for log management, even correlation, alerting, and reporting.
5. **Antivirus** - designed to detect, prevent, and remove malware, including viruses, worms, and trojans
6. **Data Loss Prevention (DLP)** - solutions identify, monitor, and protect data in use, in motion, and at rest through deep content inspection and contextual security analysis. It helps to

prevent sensitive data from being lost, misused, or accessed by unauthorized users.

7. **Simple Network Management Protocol (SNMP)** - traps are alerts sent by network devices to a management station, indicating that an event or a change in status has occurred. They are used for managing and monitoring network devices, helping admins stay informed about health and status of their networks
8. **NetFlow** - a network protocol developed by Cisco for collecting IP traffic information and monitoring network flow data. It is valuable for network traffic analysis, helping in understanding traffic patterns, usage trends, and detecting anomalies
9. **Vulnerability Scanners** - tools designed to assess computers, networks, or applications for known vulnerabilities. They are essential in a security toolkit for identifying weaknesses that could be exploited by attackers and for verifying the efficacy of security measures

Enhance Security

Saturday, July 12, 2025 4:01 PM

Firewall Configuration

Firewall - a network security device that monitors and filters incoming and outgoing network traffic based on an org's previously established security policies

Rules:

1. **Function** - specific config that control how the firewall operates. It determine which traffic should be allowed or blocked
2. **Access List** - series of commands applied to a firewall, which selectively filter traffic based on the source and destination addresses, protocols, and ports
3. **Ports/Protocols** - essential components in network comms that must be secured by firewalls

Screened subnet - or DMZ is a physical or logical subnetwork that contains and exposes org's external facing services to untrusted network, usually the internet

Web Filters - essential for controlling the websites and content that users can access, thus mitigating the risk of exposure to malicious content

1. **Agent-Based** - involves installing software agents on individual user device. It enforces web access policies set the org, regardless of the network the device is connected to
2. **Centralized Proxy** - acts as an intermediary between users and the Internet. All web traffic passes through this proxy which enforces web filtering policies.
3. **Universal Resource Locator Scanning** - involves examining the URLs requested by users to determine if they should be allowed or blocked
4. **Content Categorization** - classifies web pages into different categories based on their content. This allows orgs to block or allow entire categories of websites, making policy enforcement more streamlined and consistent
5. **Block rules** - specific criteria set to block access to certain websites or content. Can be based on URLs, keywords, categories, or other identifiable aspects of web content
6. **Reputation-based** - uses reputation score of websites to determine whether they should be allowed or blocked

Operating System Security

Group Policy - is a feature in Windows OS that allows admins to control the working environment of user accounts and computer accounts. It provides centralized management and configuration of OS, applications, and user's settings

SELinux - a security module in Linux systems that provides a mechanism for supporting access control security policies

Mandatory Access Control (MAC) - unlike traditional discretionary access control systems, SELinux enforces mandatory access control policies that admins define control access to all processes and files

Secure Protocols - ensures data integrity, confidentiality, and availability. It involves careful selection of protocols, ports, and transport methods

Protocol Selection:

- a. **HTTP vs HTTPS**: HTTPS encrypts data between client and server, safeguarding against eavesdropping and man-in-the-middle attacks
- b. **SSH vs Telnet**: SSH provides encrypted connections, while Telnet transmits data in plain text
- c. **TLS for Email**: Protocols like SMTP, IMAP, and POP3 should be secured with TLS
- d. **Secure File Transfer**: SFTP or FTPS offer secure channels for transferring files

Port Selection:

- a. **HTTPS**: default port 443
- b. **SSH**: default port 22
- c. **Email Protocols**: 587 for SMTP, 993 for IMAP, and 995 for POP3

Transport Method:

- a. **Virtual Private Network (VPN)** - creates a secure tunnel between user and the network, encrypting all data that passes through. Crucial for remote access
- b. **Internet Protocol Security (IPSec)** - used to secure Internet communications and can encrypt data between various devices like routers, firewalls, desktops
- c. **Transport Layer Security (TLS/SSL)** - cryptographic protocols designed to provide secure comms over a computer network

DNS Filter - a network security technique used to block access to malicious websites and content that is inappropriate or non-compliant with the company policies

Email Security gateway - is a hardware or software solution used to monitor and manage incoming and outgoing emails to prevent spam, phishing attacks, and other malware. It scans for viruses and other malware filters spam, can encrypt data, and prevent data loss

- **Sender policy Framework** - an email authentication method used to prevent spammers from sending messages on behalf of your domain. It verifies the sender's IP address against the list of authorized sending IPs published in the DNS records of the sender domain
- **DomainKeys Identified Mail** - provides a method for validating a domain name identity associated with an email message through cryptographic authentication. It uses digital signatures linked to a domain name to verify that the message wasn't altered in transit
- **Domain-based Message Authentication Reporting and Conformance** - an email validation system designed to detect and prevent email spoofing

File Integrity Monitoring - involves the detection and alerting of changes to files and directories on a system. Ensures that files have not been tampered with or altered by unauthorized parties

Network Access Control - primary goal is to prevent unauthorized access to network resources and to ensure that all devices and users on the network comply with the established security policy

- **Health Checks** helps in assessing the security status of devices
- **Compliance with Regulations**
- **Pre-Admission Control**
- **Post-Admission Control**

Endpoint Detection and Response (EDR) and Extended Detection and Response (XDR) - are advanced security solutions designed to provide comprehensive threat detection, analysis, and response

- **EDR** - focused on detecting, investigating, and mitigating suspicious activities and issues on hosts and endpoints
 - Continuous monitoring
 - Threat Detection
 - Response Capabilities

User Behavior Analytics - refers to the use of analytics to monitor and evaluate user behavior on IT systems and networks. It involves collecting and analyzing data on how users interact with the org's IT systems and apps. Its primary goal is to detect anomalies or deviations from normal user behavior that could indicate potential security threats

Deception and Disruption Technology - refers to the tools designed to mislead, confuse or disrupt the actions of malicious actors. These are used to create traps or illusions that protect real network assets by diverting attackers to decoy systems or files

- **Honeypot** - a security mechanism set up to detect, deflect, or study hacking attempts. It acts as decoy, imitating a real comp system, network, or information system but is isolated and monitored
- **Honeynet** - essentially a network of honeypots. It simulates a network environment to attract attackers.
- **Honeyfile** - decoy files placed within a network's file system. Designed to appear legitimate and contain attractive data but are monitored for access
- **Honeytoken** - similar to honeyfile and honeypot, a broader term that refers to any decoy

data or token inserted into a system. It can be a fake user account, database record, or any other type of digital bait

Automation and Orchestration

- **User Provisioning** - involves scripts or automated workflows to create, manage, and deactivate user accounts in various systems
- **Resource Provisioning** - involves automatically allocating and managing computing resources such as CPU, memory, and storage based on real-time demand
- **Guard Rails** - involves setting up scripts or automated controls to enforce security policies and operational best practices
- **Security Groups** - used to manage security groups, which are sets of users or systems that have common security requirements and permissions
- **Ticket creation** - automated systems can detect anomalies or issues and generate tickets automatically
- **Escalation** - involves using scripts or tools to identify high-priority incidents and escalate them to the appropriate team or individual
- **Enabling/Disabling Services and Access**
- **Continuous Integration and Testing**
- **Integrations and APIs** - allows for seamless data exchange and coordination between different components

Benefits:

1. Efficiency/Time Saving
2. Enforcing Baselines
3. Standard Infrastructure Configurations
4. Scaling in a Secure Manner
5. Employee Retention
6. Workforce Multiplier
7. Complexity
8. Cost
9. Single Point of Failure
10. Technical Debt
11. Ongoing Supportability

Identity and Access Management

Saturday, July 12, 2025 4:01 PM

Provisioning Users:

1. **Identity proofing** - involves validating that a person is who they claim to be
2. **Provisioning user accounts** - process of creating and setting up new user accounts with appropriate access rights in an organization's system and applications
3. **De-provisioning** - process of removing or disabling user accounts when they are no longer needed

Single Sign-On - a common feature where users login once and gain access to multiple systems without the need to re-authenticate

Lightweight Directory Access Protocol (LDAP) - a protocol for accessing and maintaining distributed directory information services

Federation - process of linking and managing identities across different systems and organizational boundaries. It enable users to use the same identity or set of credentials to access multiple applications or services

Security Assertion Markup Language (SAML) - an open standard for exchanging authentication and authorization data between parties, specifically between an identity provider and a service provider

Key Components:

1. Identity providers
2. Service Providers

OAuth - open standard for access delegation. Used to grant websites or apps access to their information on other websites but without giving them the passwords

OpenID Connect - an identity layer on top of OAuth 2.0. It allows clients to verify the identity of the end-user based on the authentication performed by an authorization server

Access Control Models:

Access Controls - mechanisms and policies used to manage and restrict access to resources and an information system

1. **Mandatory Access Control (MAC)** - a security model in which access rights are regulated by a central authority based on different levels of security clearance. Common in government and military systems where classified information is involved. Users cannot change access permissions, they are set and enforced by a sysadmin
2. **Discretionary Access Control (DAC)** - the resource owner decides on access levels. Most flexible. Used in environments where users need control over the resources they own, like setting the permissions in an OS. Risk of users granting excessive access, potentially leading to security breaches
3. **Role-Based Access Control (RBAC)** - assigns permissions based on a user's role within an organization. Common in corporate environments where roles define job functions and access needs. Streamlines access management.
4. **Rule-Based Access Control** - access decisions are based on a set of rules defined by a sysadmin. Useful in environments requiring stringent access control. Rules can be based on various criteria, such as source/destination IP addresses in firewalls
5. **Attribute-Based Access Control (ABAC)** - uses policies that evaluate attributes of users, the environment and resources. Effective in complex environments with diverse and dynamic user attributes. Provides fine-grained control, allowing for more nuanced access decisions based on multiple factors

Multifactor Authentication (MFA) - a security system that requires more than one method of authentication from independent categories of credentials to verify the user's identity for a login or

other transaction. This approach combines two or more distinct authentication factors

Authentication Tokens

Tokens:

1. **Hard Tokens** - physical devices used to generate secure codes
2. **Soft Tokens** - software-based approaches that generate a secure code on a user's device

Security Key - a physical hardware device used for verifying a user's identity. This usually work by being plugged into a computer or connected wirelessly. They often support protocols like Universal 2nd Factor (U2F) or FIDO2, and they authenticate by proving possession of the key in response to an authentication request

Biometric - based on unique physical attributes or behavior. It relies on the unique biological characteristics of individuals

Type 1 Error - occurs when a valid subject is not authenticated. The ratio of these errors to valid authentication is False Rejection Rate (FRR)

Type 2 Error - occurs when an invalid subject is authenticated. The ratio of these errors to valid authentication is False Acceptance Rate (FAR)

Crossover Error Rate (CER) / Equal Error Rate (EER) - point where FRR and FAR percentages are equal

Password Management

Passwords - serves as first line of defense

Best Practices:

1. **Length**
2. **Complexity**
3. **Avoid Reuse**
4. **Expiration**
5. **Age**

Password Managers - store and encrypt passwords, requiring the user to remember only one strong master password

Privileged Access Management Tools - used to control, manage, and monitor access to critical systems and resources within an organization, particularly focusing on privileged users who have elevated access rights

Just-in-Time - permissions grant privileged access on an as-needed basis, typically for a limited period. Reduces the risk of privilege abuse by ensuring privileges are granted only when necessary

Password Vaulting - involves securely storing and managing credentials for privileged accounts in a centralized repository

Ephemeral Credentials - are temporary credentials that are generated on-demand and expire after a short duration

Incident Response

Saturday, July 12, 2025 4:02 PM

Incident Response Steps:

- **Security Incident** - an event that compromises the confidentiality, integrity, or availability of information assets
- **Security Incident Process** - process of handling a security incident typically involves several key steps, designed to effectively identify, manage, and mitigate the incident

Steps:

1. **Preparation** - foundational stage where orgs develop incident response plans, establish incident response teams, and set up necessary tools and communication channels. This includes training personnel, conducting regular security assessments, and ensuring that all necessary resources are in place to handle a security incident
2. **Detection** - involves identifying potential security incidents. Can be achieved through network monitoring, intrusion detection systems, and regular security audits
3. **Analysis** - involves determining the type of attack, the systems affected, the data compromised, and the attacker's tactics, techniques, and procedures (TTPs)
4. **Containment** - aims to limit the scope and magnitude of the incident. This involves isolating affected systems, blocking malicious traffic or temporarily shutting down certain services
5. **Eradication** - eradication of the root cause of the incident. It involves removing malware, closing security gaps, restoring systems, and implementing patches
6. **Recovery** - affected systems and services are restored to normal operations. Includes ensuring that all systems are cleaned and secure before bringing them back online. Also involves monitoring for any signs of recurrence or fallout from the incident
7. **Lessons Learned** - involves analyzing what happened, how it was handled, and what could be done better in the future

Incident Response Training:

- **Training** - focuses on the educational and skill-building aspects necessary for preparing individuals and teams to effectively respond to cybersecurity incidents
- **Testing** - crucial for identifying gaps in incident response plans and improving the overall readiness of the response team
 - **Tabletop exercise** - a discussion-based session where team members walk through various incident scenarios in a structured manner.
 - **Simulations** - more hands-on and involve creating a realistic cyber incident environment where the response team can practice responding to an incident. This includes the use of real tools and systems in a controlled setting
- **Root Cause Analysis** - involves exploring the systematic process used to identify the underlying reasons why a security incident occurred. It helps prevent future incidents by addressing the core issues rather than just their symptoms
- **Threat Hunting** - involves exploring the proactive and iterative approach to detecting and isolating advanced threats that evade existing security solutions. It is a crucial component in identifying and mitigating sophisticated cyber threats.

Digital Forensics - involves delving into the methodologies and principles applied in the investigation of cyber incidents, focusing on the identification, collection, examination, and preservation of digital evidence

- **Legal Hold** - where potentially relevant data is preserved for legal or investigative purposes. Involves ensuring such data is not altered, deleted, or destroyed during the course of an investigation
- **Chain of Custody** - refers to the documentation or paper trail that records the sequence custody, control, transfer, analysis, and disposition of physical or electronic evidence

- **Acquisition** - process of collecting digital evidence while ensuring that the data is not altered during the process. Involves creating copies of hard drives, memory, or other storage media using specialized tools that ensure the original evidence remains unaltered
- **Reporting** - involves documenting the findings of the forensic investigation. Includes detailing how the evidence was collected, analyzed, and preserved, as well as the conclusions drawn from the analysis
- **E-Discovery** - process of identifying, collecting, and producing electronically stored information in response to a request for production in a legal case or investigation

Log Data - one of the primary data sources in an investigation

Types of Logs:

1. **Firewall Logs** - record events related to the network firewall, including attempted and blocked connections, allowed traffic, and rule changes
2. **Application Logs** - provide records of events from specific applications. It can include information about application performance, user activities, errors, and security events
3. **Endpoint Logs** - generated by endpoint devices like laptops, desktops, and mobile devices. They can contain information about operations and activities on the device, including system changes, user activities, and security events like antivirus alerts
4. **OS-Specific security Logs** - provide details about events specific to the OS. This includes user logon/logoff activities, system errors, policy changes, and security-related changes
5. **IPS/IDS Logs** - record information about network traffic and potential security threats. Used to identify suspicious activities, policy violations, and attempted or successful breaches of the network security
6. **Network Logs** - record data about the activities within a network, including traffic flow, device connectivity, and network errors. Essential for understanding the baseline network activity and identifying deviations that might suggest a security issue
7. **Metadata** - refers to data that provides information about other data. This can include details about file creation and modification, sender/recipient information in emails, and location data. Can be used to trace activities and establish patterns relevant to an investigation

Data Sources - provide crucial insights and evidence for understanding the nature of security incidents, their impact, and methods for remediation

1. **Vulnerability scans** - automated tools that assess systems, networks, and applications for security weaknesses. Critical for understanding attack vectors and potential entry points for attackers
2. **Automated reports** - generated by various security tools and systems. Useful for gaining a high-level overview of the security posture and identifying patterns or anomalies that may require further investigation
3. **Dashboards** - provide a real-time view of an organization's security status, aggregating data from multiple sources into a single interface. Essential for ongoing monitoring and quick detection of issues as they arise
4. **Packet Captures** - involves recording network traffic and analyzing the packets that travel across the network. Invaluable for understanding the nature of network-based attacks, investigating data exfiltration, and analyzing communication between compromised systems and attackers' command and control servers

Security Governance and Privacy

Saturday, July 12, 2025 4:02 PM

Security Policies, Standards, Guidelines, and Procedures:

Security Governance - collection of practices related to supporting, evaluating, defining, and directing the security efforts of an organization

- Establish and sustain a culture of security in the organization's conduct
- Establish and maintain a framework to provide assurance that infosec strategies are aligned with business objectives
- Assure that infosec is consistent with applicable laws and regulations
- Assess emerging threats and provide strong cyber security leadership

Policies - provides a framework for consistent and secure operations across the organization. It forms the foundation for how an organization secures its assets, responds to incidents, and ensures continuity of operations

- **Acceptable Use Policy** - defines the acceptable ways in which network, systems, and information can be used by employees and other users. Typically covers the use of organizational resources, internet usage, email, and social media guidelines
- **Information Security Policies** - encompasses a broad range of guidelines designed to protect the confidentiality, integrity, and availability of information. It covers aspects like data classification, access controls, cryptography and physical security
- **Business Continuity Policy** - outline procedures and instructions an organization must follow in the face of major disruptions or disasters. Includes maintaining essential functions and services during and after a major disruption
- **Disaster Recovery Policy** - focuses on restoring IT systems, data, and infrastructure to operational status after a disaster. Includes detailed plans on data backups, system recovery processes, and roles and responsibilities during the recovery process.
- **Incident Response Policy** - provides a structured approach for managing security incidents and breaches. Defines roles, responsibilities, processes and comms strategies to be employed during and after an incident
- **Software Development Lifecycle Policy** - govern the processes involved in developing, deploying, and maintaining software
- **Change Management Policy** - critical for ensuring that changes to IT systems and environments are made in a controlled and secured manner. Includes evaluating, approving, and documenting changes to prevent unauthorized modifications that could compromise security

Standards - established benchmarks or sets of criteria against which security measures are designed and evaluated

- **Password Standards** - define the criteria for creating and managing passwords
- **Access Control Standards** - specify how access to information systems and data should be controlled and managed
- **Physical Security Standards** - address the protection of hardware, software, networks, and data from physical actions and events that could cause serious loss or damage
- **Encryption Standards** - outline the requirements for encrypting data, both at rest and in transit

Guidelines - sets of recommendations and best practices that help shape and organization's security posture and decision making. It provides the roadmap for org to develop, implement, and maintain robust security practices that align with their business objectives and risk tolerance levels

Procedures - detailed, operational-level instructions that guide the day-to-day activities maintaining security

- **Change Management Procedures** - ensures that all changes to IT systems, software, and infrastructure are made in a controlled, systematic manner
- **Onboarding/Offboarding Procedures:**

- Onboarding procedures - involve steps for integrating new employees into the organization securely
- Offboarding procedures - ensure that when employees leave the org, their access to systems and data is revoked and any sensitive information they handled is secured
- **Playbooks** - sets of procedures that detail the steps to be taken in response to specific security incidents or scenarios

Security Governance Considerations and Revisions:

- **External Considerations** - these shape and often mandate certain aspects of security governance
- **National Regulatory and Legal Considerations** - orgs must comply with various industry-specific and general data protection regulations. These regulations often dictate specific security measures and processes
- **Local/Regional Considerations** - may vary significantly from one jurisdiction to another. Includes the state or regional data protection laws and regulations
- **Global Considerations** - includes understanding and complying with the cybersecurity laws and regulations of all the countries in which they operate. It also involves dealing with cross-border data transfers and multinational regulatory compliance
- **Industry Considerations** - different industries often have unique cybersecurity challenges and standards
- **Monitoring and revision** - involves understanding the ongoing processes of overseeing security operations and making necessary adjustments to enhance and maintain the security posture.
- **Effective Governance** - requires not only the implementation of robust security measures but also their ongoing evaluation and adaptation to meet the changing security landscape and organizational needs

Security Governance Structures:

Types:

- **Boards** - sets the tone at the top, establishes strategic priorities, and ensures that cybersecurity risks are adequately considered in the org's overall risk management
- **Committees** - have more specialized focus areas and are responsible for overseeing the implementation of policies, compliance, and risk management strategies
- **Government Entities** - set the standards and regulations that organizations must comply with
- **Centralized Governance** - allows for uniform policy enforcement and steam-lined decision-making but may lack the flexibility or specific focus of decentralized systems
- **Decentralized Governance** - can offer greater specialization and alignment with specific business needs but may face challenges in ensuring consistent policy implementation and coordination

Security Governance Roles:

- **Owners** - typically senior management members or department heads who have overall accountability for specific information assets. Responsible for ensuring that proper controls are in place to protect the data and for making strategic decisions regarding the data's use, security, and handling
- **Custodians/Stewards** - responsible for the technical management and protection of data. They implement and maintain security measures, manage access controls, and ensure the proper operation of systems that store or process the data
- **Controllers** - entities that determine the purposes and means of processing personal data
- **Processors** - entities that process data on behalf of the controller. Responsibilities include processing data securely as per the controller's instructions and ensuring that their activities comply with the relevant data protection laws and organizational policies

Compliance Reporting - refers to the process of documenting and conveying an organization's adherence to various cybersecurity regulations, standards, and internal policies

- **Internal Compliance Reporting** - involves generating reports for use within the organization

typically for management, internal audit teams, or IT security departments

- **External Compliance Reporting** - prepared for outside entities such as regulatory bodies, clients, or third-party auditors
- **Consequences of non-Compliance** - refers to the adverse effects and org faces when it fails to adhere to relevant cybersecurity laws, regulations, standards, or contractual obligations
 - Fines
 - Sanctions - formal penalties or restrictions imposed by regulatory authorities or governing bodies
 - Reputational Damage - erosion of trust and confidence among clients, partners, and the public
 - Loss of License
 - Contractual Impacts
 - Operational Disruptions
 - Increased Scrutiny and Ongoing Monitoring - refers to the ongoing process of ensuring that an organization meets the required standards and regulations for cybersecurity
 - Due Diligence/Care - involves the continuous effort to ensure that all cybersecurity practices, policies, and legal controls are in line with the latest legal and regulatory requirements
 - Attestation - involves formal verification, confirming that an org's cybersecurity controls meet certain standards or regulations
 - Acknowledgement - refers to org's recognition and acceptance of its cybersecurity responsibilities
 - Internal Monitoring - consists of activities conducted within the org to ensure compliance
 - External Monitoring - involve assessments or audits by external parties
 - Market and Competitive Disadvantages

Privacy - refers to the practices, policies, and legal requirements surrounding the protection of personal and sensitive data. It is heavily regulated, with implications varying across local, regional, national, and global jurisdictions

- **Personal Identifiable Information (PII)** - information when used alone or with other relevant data, can identify an individual
- **Protected Health Information (PHI)** - referred to as personal health information, is the demographic info, medical histories, test, and lab results, mental health conditions, insurance info and other data that a healthcare professional collects to identify an individual and determine appropriate care
- **Data Subject** - an individual whose personal data is processed by an organization

Risk Management

Saturday, July 12, 2025 4:02 PM

Risk Terms:

- **Risk** - probability of a threat exploiting a vulnerability
- **Asset** - anything within an environment that should be protected
- **Asset Valuation** - a dollar value assigned to an asset based on actual cost and nonmonetary expenses
- **Threats** - any potential occurrence that may harm the asset
- **Threat Agent / Actors** - people, programs, hardware, or systems that use threats to cause harm
- **Threat Events** - occurrences that lead to the exploitations of vulnerabilities
- **Threat Vector** - the path or means by which an attack or attacker can gain access to a target in order to cause harm
- **Vulnerabilities** - weakness in an asset or the absence or the weakness of a safeguard or countermeasure that could be exploited
- **Exposure** - actual or anticipated damage from a threat
- **Safeguards** - anything that removes or reduces a risk
- **Attack** - threat exploiting the vulnerability
- **Breach** - occurrence of a security mechanism being bypassed or thwarted by a threat agent

Risk Identification and Assessment Times

- **Risk Identification** - involves understanding the initial phase of the risk management process where potential security risks are recognized and described
- **Adhoc Risk Assessment** - performed as needed, often in response to specific events or changes in the environment
- **Recurring Risk Assessment** - part of a systematic approach to risk management and ensure that changes in the org's environment, assets and threat landscape are consistently accounted for and addressed
- **One-Time Risk Assessment** - conducted for specific scenarios, such as before launching a new product, implementing a new IT system or entering a new market
- **Continuous Risk Assessment** - involves ongoing monitoring and analysis of the risk landscape

Quantitative and Qualitative Risk Assessment

- **Quantitative Risk Analysis** - comes into play when we can map a monetary amount to an identified risk
- **Qualitative Risk Analysis** - involves assessing risks based on subjective criteria, such as expert opinions, scenario analysis, and industry best practices

Risk Register - component of effective risk management, serving as a centralized repository for information about identified risks, their assessment, and actions taken to mitigate them

- **Description** - the nature of risk, the assets or areas affected, and the potential consequences if the risk were to materialize
- **Key Risk Indicators (KRI)** - metrics used to measure and monitor the likelihood and impact of risks. They provide early warning signs that a risk may be increasing or decreasing in severity
- **Risk Owner** - person or an individual who is responsible for managing and mitigating that specific risk
- **Risk Threshold** - level of risk that the org is willing to accept

Risk Appetite - refers to the risk that in organization is prepared to pursue, retain or take in its operations

- **Risk tolerance** - the amount of risk the organization is willing to take
- **Expansionary Risk Appetite** - indicates a willingness to take on higher levels of risk in pursuit of greater rewards
- **Conservatory Risk Appetite** - implies a preference for lower risk and a focus on stability and predictability

- **Neutral Risk Appetite** - strikes a balance between expansionary and conservative approaches

Risk Response:

- **Risk Avoidance** - involves changing plans or procedures to eliminate the risk or to remove the organization's exposure to it
- **Risk Mitigation** - refers to taking steps to reduce the likelihood or impact of the risk. Implementing security controls, updating software, improving user training, and enhancing monitoring and detection capabilities
- **Risk Transfer** - shifting the impact of a risk to a third party
- **Risk Acceptance** - a conscious decision to not take any action against a particular risk
- **Risk Exploitation** - involves taking advantage of the potential positive impacts of a risk
- **Risk Reporting** - involves understanding the process of communication information about identified risks, their analysis, and mitigation strategies to relevant stakeholders

Business Impact Assessment

- **Business Impact Analysis** - helps in identifying and evaluating the potential effects of interruptions to critical business operations. It is a proactive measure that aids in crafting effective business continuity and disaster recovery strategies, ensuring business resilience in the face of cyber threats
- **Recovery Time:**
 - **Maximum Tolerable Downtime (MTD)** - defines the amount of time a business function can be inoperable without causing irreparable harm to the business | **RTO < MTD**
 - **Recovery Time Objective (RTO)** - amount of time to recover the function in the event of a disaster | **RTO < MTD**
 - **Recovery Point Objective (RPO)** - defines the point in time before the data loss during the outage will leave the business function unrecoverable
- **Failure Time:**
 - **Mean Time to Repair (MTTR)** - average time taken to repair a failed component, system, or function and return it to operational status
 - **Mean Time Between Failures (MTBF)** - measure of reliability and stability of IT systems indicating the average time between inherent failures of a system or component in normal operating conditions

Vendor Management

Saturday, July 12, 2025 4:02 PM

Vendor Management and Selection

- **Vendor Assessment** - process of evaluating and monitoring the security risks associated with third party service providers or suppliers. It involves scrutinizing vendors cybersecurity practices, policies, and compliance with relevant standards through methods such as penetration testing, reviewing audit reports, and assessing their data handling and privacy measures
- **Penetration testing** involves simulating cyberattacks against a vendor's systems to assess the security of their systems and services
- **Right-to-Audit Clause** - vendor grants the org to the right to conduct, or have conducted on its behalf, an audit of the vendor's security practices
- **Evidence of Internal Audits** - vendors should provide evidence of regular internal audits of their security processes and controls
- **Independent Assessments** - provide an objective evaluation of the vendor's security posture
- **Supply Chain Analysis** - involves examining the security of the vendor's supply chain
- **Questionnaires** - critical tool used for gathering essential information about a vendor's security practices, policies and compliance status
- **Rules of Engagement** - refer to the set of guidelines or protocols that outline how an organization interacts and cooperates with third party vendors
- **Due Diligence** - a comprehensive appraisal of a vendor's business practices, focusing on their cybersecurity policies, procedures, and controls
- **Conflict of Interest** - ensures the transparency and impartiality in the selection process is key to avoiding biases or decisions that could compromise security
- **Vendor Monitoring** - continuous process of assessing and overseeing third-party vendors to ensure they comply with established security standards and contractual agreements

Vendor Agreements

- **Contractual agreements** - aligns with the org's security expectations. Data protection, incident response, regular security audits, and the right-to-audit clause
- **Service Level Agreement** - a contract between a service provider and a client that specifies the level of service expected during the term of the agreement. Usual aspects like system uptime, response times for support requests, and security measures
- **Memorandum of Agreement** - a formal document outlining an agreement between two or more parties
- **Memorandum of Understanding** - a less formal than MOA, used to outline a mutual agreement on a shared goal or project, without legal obligations
- **Master Service Agreement** - a comprehensive contract that sets the general terms governing future transaction or agreements
- **Work Order/Statement of Work** - a document that provides specific details about the work to be performed under a contract
- **Non-disclosure Agreement** - a legally binding contract that establishes a confidential relationship. Parties agree not to disclose information covered by the agreement
- **Business Partner Agreement** - outlines the terms and conditions of the relationship between business partners

Physical Security

Saturday, July 12, 2025 4:02 PM

Physical Security - focuses on protecting an organization's assets, including buildings, equipment, and personnel, from physical actions and events that could cause serious loss or damage

- **Bollards** - sturdy, vertical posts designed to prevent car-based attacks on building
- **Access Control Vestibule** - a secured area between two sets of doors used to manage and control access into a secure area
- **Fencing** - used to secure the perimeter of a property
- **Video Surveillance** - the use of cameras to monitor activities in and around a facility
- **Security Guard** - human security presence
- **Access Badge** - used to identify authorized personnel and often contain magnetic strips of RFID chips to allow access to secured areas
- **Lighting** - enhances visibility, acting as a deterrent to trespassers and aiding in the effectiveness of video surveillance
- **Sensors:**
 - Infrared - detect heat and movement
 - Pressure - detect changes in pressure
 - Microwave - use microwave pulses to detect movement
 - Ultrasonic - emit ultrasonic waves and measure the reflection of a moving object

Change Management

Saturday, July 12, 2025 4:02 PM

Change Management - a structured approach to transitioning individuals, teams, and organizations from a current state to a desired future state

Approval Process - ensures that any changes, especially those affecting IT systems and security infrastructure, are reviewed and approved by the authorized personnel before implementation

Ownership - refers to identifying who is responsible for overseeing the change process

Stakeholder - process include anyone who may be affected by the change or who has influence over the process

Impact Analysis - involves evaluating the risks and benefits of the change, how it might affect existing security controls, and what new risks it might introduce

Test Results - helps in identifying any unforeseen security issues

Backout Plan - a contingency plan that can be activated if the changes introduces unacceptable risks or cause unforeseen issues.

Maintenance Window - a predefined period during which changes are implemented

Standard Operating Procedure - detailed, written instructions to achieve uniformity in the performance of specific functions

Technical Implications - refer to the direct effects that changes in an IT environment can have on system security, functionality, and performance

Allow Lists/Deny Lists - changes in security configs, such as updating firewall rules or access control lists

Restricted Activities - changes in system config or policies might impose new restrictions on user activities

Downtime - security risks can arise if downtime is not properly managed such as increased vulnerability during system reboots or updates

Service Restart - can temporarily expose security vulnerabilities. Planning for service restarts involves ensuring that security measures are promptly reinstated

Application Restart - ensuring applications maintain their security configs upon restart is crucial, similar to service restart

Legacy Applications - older applications might not be compatible with new systems or security protocols

Dependencies - a change in one component can affect other dependent systems

Documentation - maintaining clear record of all changes, their reasons, and their impacts on systems and security

Updating Diagrams - assesses the potential impacts of changes on various parts of the system

Updating Policies/Procedures

Version Control - practice of managing changes to software code, configs, and other data, usually in a collaborative environment

Resilience and Recovery

Saturday, July 12, 2025 4:03 PM

High Availability - ensuring that systems, apps, and services are available to users over a desired period, typically aiming for near-continuous availabilities. Involves designing systems that can prevent or quickly recover from failures, thereby minimizing downtime

- **Load Balancing** - a technique used to distribute workloads evenly across multiple servers or resources
- **Clustering** - refers to a group of interconnected computers or servers that work together as a single system

Site Selection - ensures that organization can maintain continuity and protect their assets in the face of disruptions

- **Hot Sites** - a fully functional and equipped data center that can be switched to immediately in case the primary site fails
- **Cold Sites** - a location equipped with the necessary infra to support IT operations but without computers, data and applications
- **Warm sites** - a middle ground between hot and cold sites. Contains some pre-installed and configured equipment, requiring less time to become operational than a cold site
- **Geographic Dispersion** - involves distributing IT resources and sites across different geographic locations
- **Platform Diversity** - involves balancing the benefits of diverse tech platforms with the challenges of managing a more complex IT environment
- **Multi-cloud systems** - the use of cloud computing services from multiple providers
- **Continuity of Operations** - refers to an organization's ability to continue its essential functions, even in the face of a major disruption or disaster

Capacity Planning - involves forecasting and preparing for the future resources needed to manage infosec effectively. Encompasses the assessment of the current capabilities and the anticipation of future needs

- **People** - ensures an org has enough skilled cybersecurity professionals to handle various tasks, including incident response, risk assessment, and system maintenance
- **Technology** - implementing security technologies that can scale with the org's growth and evolving threat landscape
- **Infrastructure** - ensures the IT infra can support both current and anticipated future cybersecurity needs

Testing

- **Tabletop Exercises** - discussion based sessions where team members gather to walk through various cybersecurity scenarios. Assess the teams understanding and preparedness for handling different type of cyber incidents
- **Failover Testing** - critical for verifying the reliability and effectiveness of backup systems and processes. Involves causing a system's primary processing capabilities to fail to test whether the failover process to a secondary system occurs smoothly and without significant disruptions
- **Simulation** - realistic, controlled tests designed to mimic the conditions of a genuine cyberattack
- **Parallel Processing** - tests the ability of an org to handle operations on multiple systems simultaneously

Backups - copies of data and systems that are stored separately from the original, designed to be used for restoring the original in case of data loss, corruption, or a disaster

- **Onsite** - backups stored at the same physical location as the primary data source
- **Offsite** - backups are stored at a different location
- **Frequency** - determined based on the criticality of the data and the rate at which it changes
- **Encryption** - maintains the confidentiality and integrity of data, should be applied to both transmission and at rest

- **Snapshots** - method of capturing the state of a system at a particular point in time
- **Recovery** - involves processes and plans to restore data and systems from backups efficiently and effectively after a data loss incident
- **Replication** - involves copying data to a secondary location in real-time or near-real-time
- **Journaling** - a method that keeps track of changes made to the data since the last full backup

Power - ensuring consistent and reliable power supply is vital for maintaining the availability and functionality of IT systems, especially in the face of power disruptions or failures